



User and computer accounts

Ing. Ondřej Ševeček | GOPAS a.s. |

MCSM:Directory2012 | MCM:Directory2008 | MVP:Enterprise Security |
Certified Ethical Hacker | CISA |

ondrej@sevecek.com | www.sevecek.com |

GOPAS: info@gopas.cz | www.gopas.cz | www.facebook.com/P.S.GOPAS

User accounts recap

- Two logins
 - **sAMAccountName**: gps\kamil
 - ◆ 20 characters limit
 - **userPrincipalName**: rychnovsky.kamil@gopas.cz
 - ◆ can have variable UPN suffixes
 - ◆ 64 characters limit on login prefix, and 64 chars UPN suffix
- Password stored in AD or local SAM database
 - hashed form (full-text can be enabled)
- Stores **hash history**
 - up to 24 hashes
- Applies password policies
 - complexity, length, regular expiration, history

Password modifications

- Change (změnit)
 - LDAP method ChangePassword(), Win32 function NetUserChangePassword()
 - Everyone as long as the current password is supplied
- Reset (nastavit)
 - LDAP method ResetPassword(), Win32 function NetUserSetInfo()
 - **administrative action**, no previous password knowledge
 - ◆ no history constraint (history yet pushed further)
 - ◆ no minimum password age
- Interfaces in Secure Channel, LDAP**S**, Kerberos
 - SMB TCP 445 named pipes, Netlogon DCOM, TCP 636 (389), TCP/UDP 464

Interesting point about password history #1

- Password history check (N-2)
- `badPasswordCount` and `badPasswordTime` do not update for two previous password attempts
 - requires password history with at least 2 previous hashes

Interesting point about password history #2

- 1 hour after a password change
- NTLM and LDAP simple bind can use previous password for logon
 - requires password history enabled
 - (example - for sure works with IIS NTLM provider)
- Does not apply to Kerberos

Password and account expiration

■ Password expiration

- 0xC0000071 = STATUS_PASSWORD_EXPIRED
- 0xC0000224 = STATUS_PASSWORD_MUST_CHANGE
- 0x17 = KDC_ERR_KEY_EXPIRED
- The user account's password has expired
- cannot log on at all, **visual effect** is just different
- controlled by **pwdLastSet** attribute
- "Must change password at next logon"
 - ◆ pwdLastSet = 0

■ Account expiration

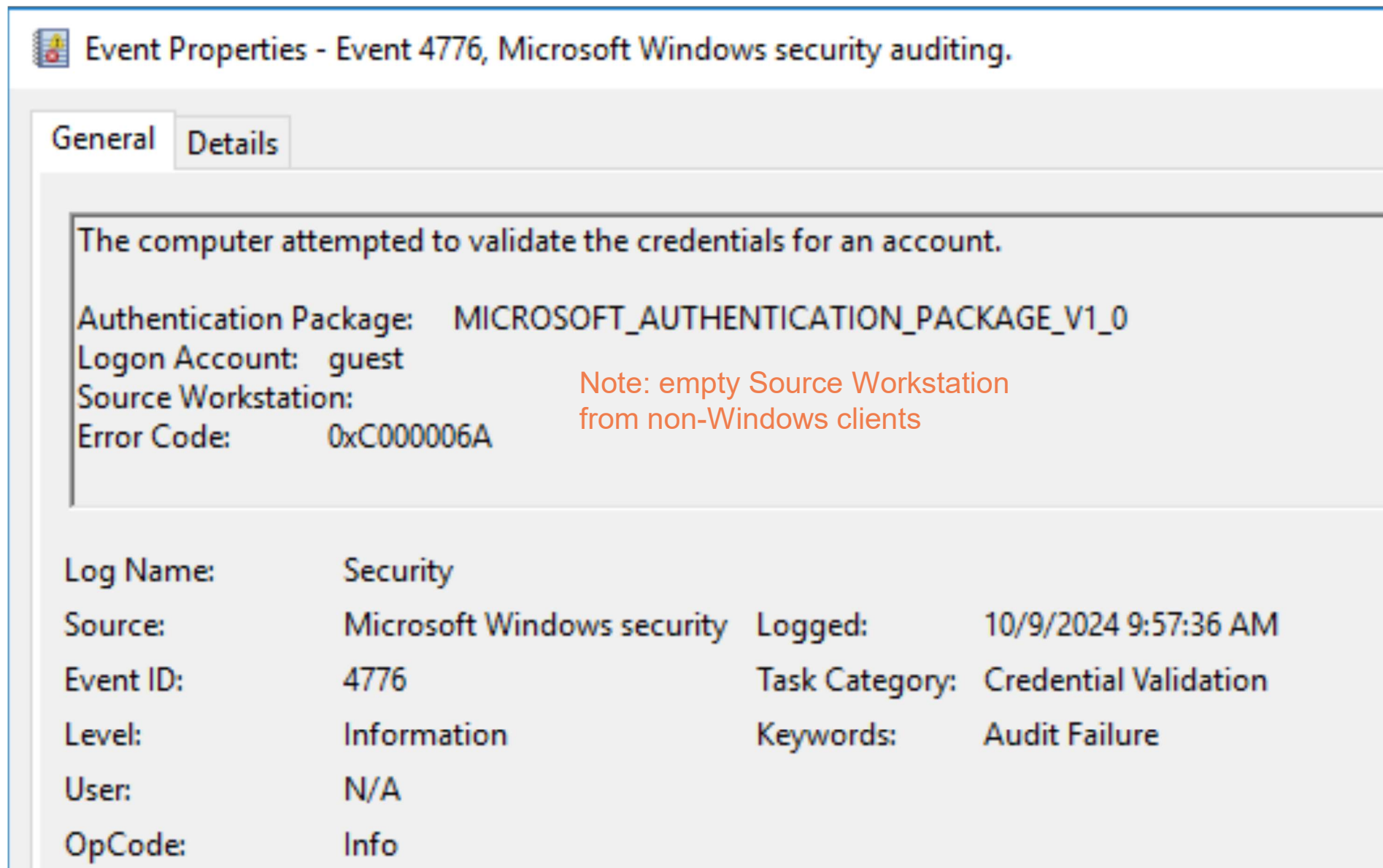
- 0xC0000193 = STATUS_ACCOUNT_EXPIRED
- 0x12 = KDC_ERR_CLIENT_REVOKED (TGT request)
- 0x01 = KDC_ERR_NAME_EXP (TGS request)
- "The user's account has expired"

Other account authentication failures

- incorrect login
 - 0x6 = KDC_ERR_C_PRINCIPAL_UNKNOWN (event ID = 4771, Kerberos Authentication Service)
 - 0xC000006D = STATUS_LOGON_FAILURE (event ID = 4625, Logon)
 - 0xC0000064 = STATUS_NO_SUCH_USER
- bad password
 - 0x18 = KDC_ERR_PREAUTH_FAILED (event ID = 4771, Kerberos Authentication Service)
 - 0xC000006D = STATUS_LOGON_FAILURE (event ID = 4625, Logon)
 - 0xC000006A = STATUS_WRONG_PASSWORD
- account locked out
 - 0x12 = KDC_ERR_CLIENT_REVOKED (event ID = 4771, Kerberos Authentication Service)
 - 0xC0000234 = STATUS_ACCOUNT_LOCKED_OUT (event ID = 4625, Account Lockout)
- account disabled
 - checking even before trying password
 - 0x12 = KDC_ERR_CLIENT_REVOKED (event ID = 4771, Kerberos Authentication Service)
 - 0xC000006E = STATUS_ACCOUNT_RESTRICTION (event ID = 4625, Logon)
 - 0xC0000072 = STATUS_ACCOUNT_DISABLED
- Smart card is required for interactive logon
 - checking even before trying password
 - 0xC = KDC_ERR_POLICY (event ID = 4771, Kerberos Authentication Service)
 - 0xC000006E = STATUS_ACCOUNT_RESTRICTION (event ID = 4625, Logon)
 - 0xC00002FA = STATUS_SMARTCARD_LOGON_REQUIRED
- logon workstations
 - checking even before trying password
 - 0xC = KDC_ERR_POLICY (event ID = 4771, Kerberos Authentication Service)
 - 0xC000006E = STATUS_ACCOUNT_RESTRICTION (event ID = 4625, Logon)
 - 0xC0000070 = STATUS_INVALID_WORKSTATION
- logon hours
 - checking even before trying password
 - 0x12 = KDC_ERR_CLIENT_REVOKED (event ID = 4771, Kerberos Authentication Service)
 - 0xC000006E = STATUS_ACCOUNT_RESTRICTION (event ID = 4625, Logon)
 - 0xC000006F = STATUS_INVALID_LOGON_HOURS

Different order of checking password vs. account states

Note: Kerberos checks account status first and only then its password, while NTLM may lock even disabled accounts



The screenshot displays the 'Event Properties' window for Event 4776, titled 'Microsoft Windows security auditing'. The 'General' tab is active, showing a description of the event: 'The computer attempted to validate the credentials for an account.' Below this, the 'Authentication Package' is listed as 'MICROSOFT_AUTHENTICATION_PACKAGE_V1_0', the 'Logon Account' as 'guest', and the 'Error Code' as '0xC000006A'. A note specifies that the 'Source Workstation' is empty, indicating a non-Windows client. The bottom section provides a summary of the event's metadata, including the log name, source, event ID, level, user, and opcode, along with the log date and task category.

Event Properties - Event 4776, Microsoft Windows security auditing.			
General Details			
The computer attempted to validate the credentials for an account.			
Authentication Package: MICROSOFT_AUTHENTICATION_PACKAGE_V1_0			
Logon Account: guest			
Source Workstation:			
Error Code: 0xC000006A			
Note: empty Source Workstation from non-Windows clients			
Log Name:	Security	Logged:	10/9/2024 9:57:36 AM
Source:	Microsoft Windows security	Task Category:	Credential Validation
Event ID:	4776	Keywords:	Audit Failure
Level:	Information		
User:	N/A		
OpCode:	Info		

Event filters and logins (SAM login if found, or what the user supplied exactly)

```
* [  
  
System[Provider[@Name='Microsoft-Windows-Security-Auditing']]  
  
and  
  
System[TimeCreated[timediff(@SystemTime) <= 3600000]]  
  
and  
  
(  
  
EventData/Data[@Name='SubjectUserName'] = 'kamil'  
or  
EventData/Data[@Name='TargetUserName'] = 'kamil'  
or  
EventData/Data[@Name='AccountName'] = 'kamil'  
or  
EventData/Data[@Name='SubjectUserName'] = 'failure.invalid.login@gopas.cz'  
or  
EventData/Data[@Name='TargetUserName'] = 'failure.invalid.login@gopas.cz'  
or  
EventData/Data[@Name='AccountName'] = 'failure.invalid.login@gopas.cz'  
  
)  
  
]
```

Event filters and WEVTUTIL

```
wevtutil qe Security /r:DC1 /f:XML  
'/q:*[System[TimeCreated[timediff(@SystemTime)<=3600000]]]' >  
c:\temp\lastHour.xml
```

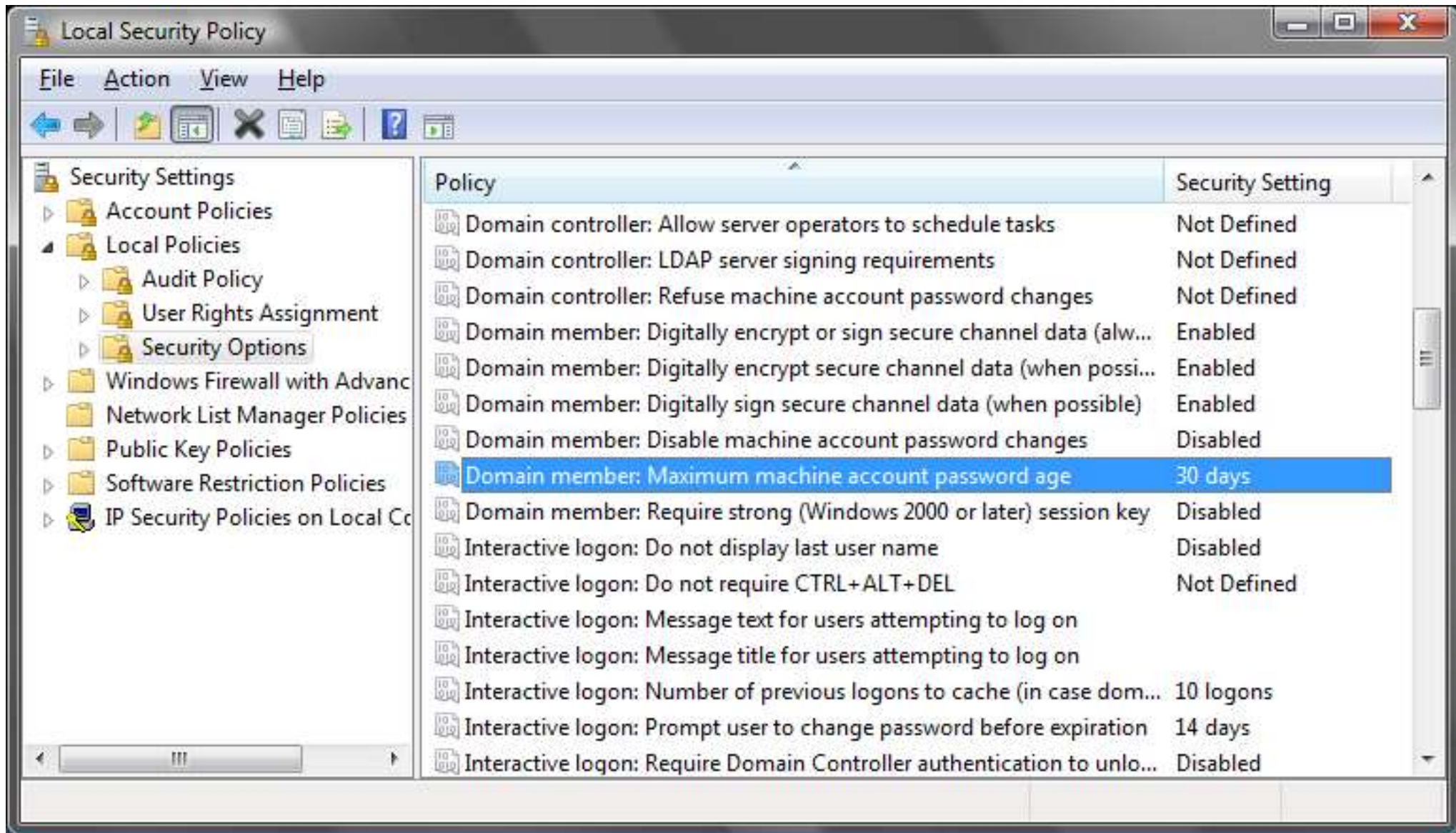
Computer accounts

- AD classes
 - user, computer
- `userPrincipalName` = -
- `sAMAccountName` = comp\$
- No password policies
 - never lock out
 - no complexity enforced
 - history maintained because of the previous two specials
 - never expires

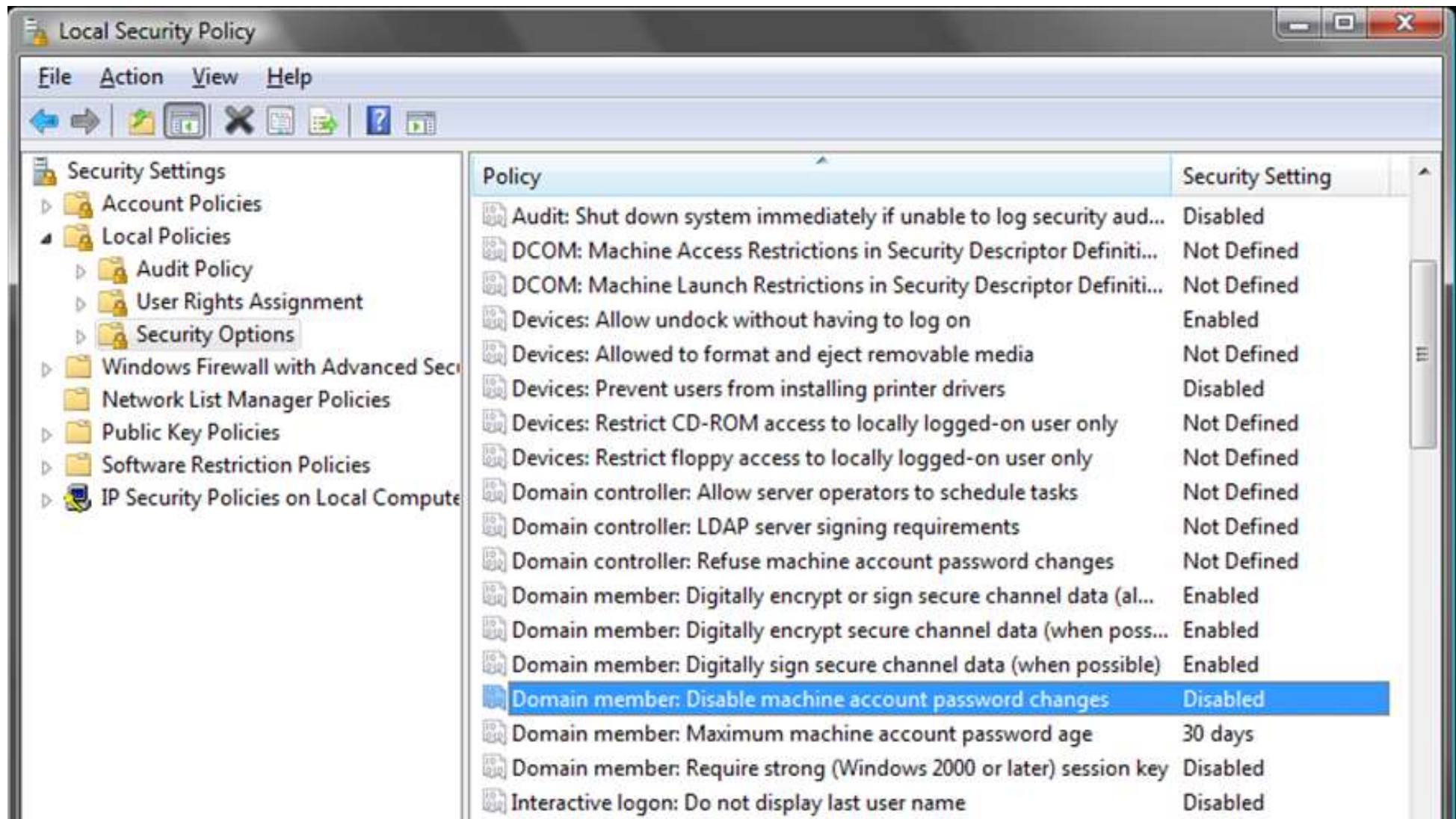
Computer account password

- Stored locally in registry
 - HKLM\SECURITY\Policy\Secrets\SMACHINE.ACC
 - ◆ current and previous password
 - ◆ full-text version
- Changed regularly every 30 days
 - does not change if offline

Maximum machine account password age



Disable machine account password changes



Computer password change event on DC

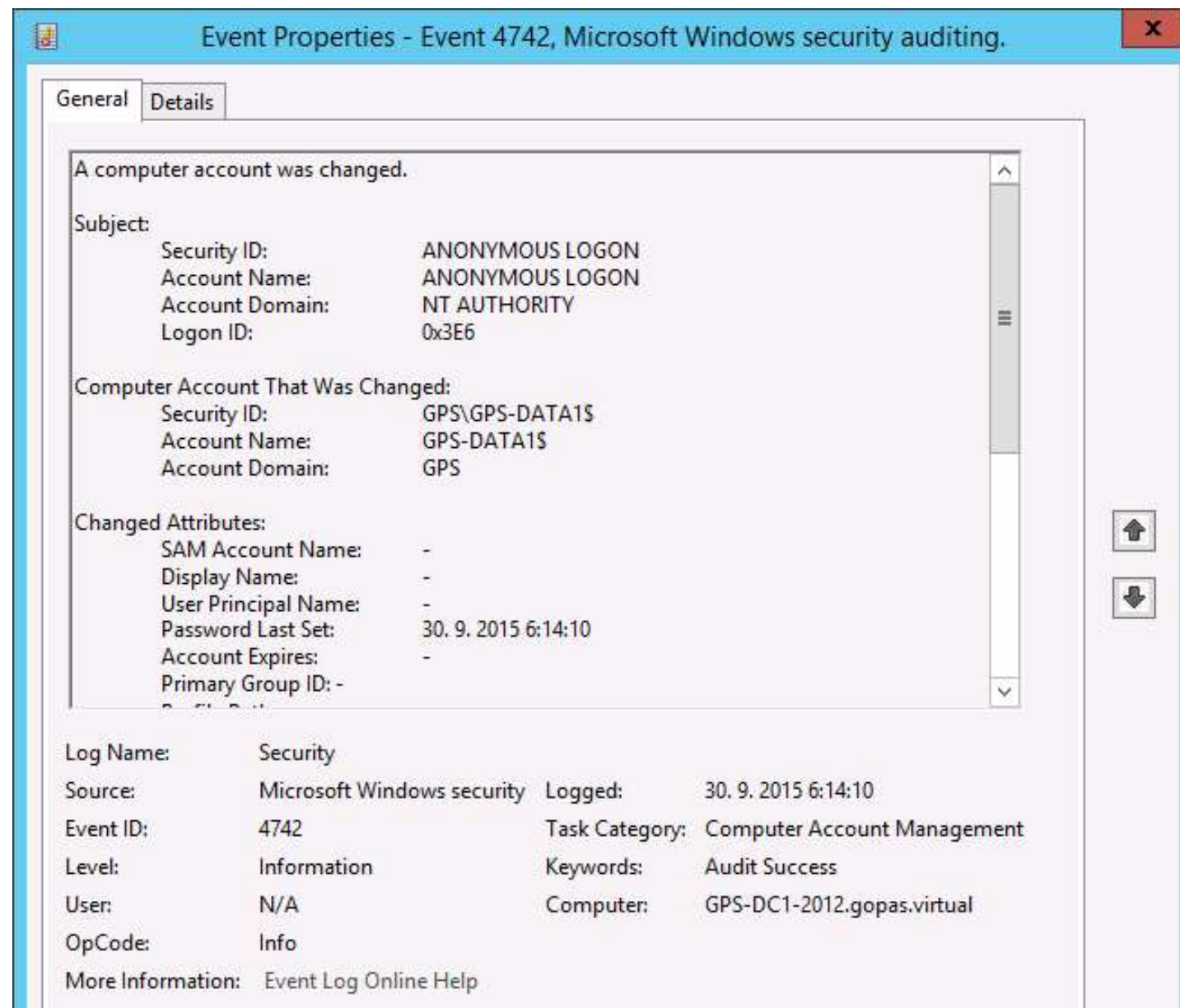
Audit Success

Event ID: 4742

Source: Microsoft
Windows security
auditing

Category: Computer
Account Management

Password Last Set
attribute modified by
ANONYMOUS LOGON

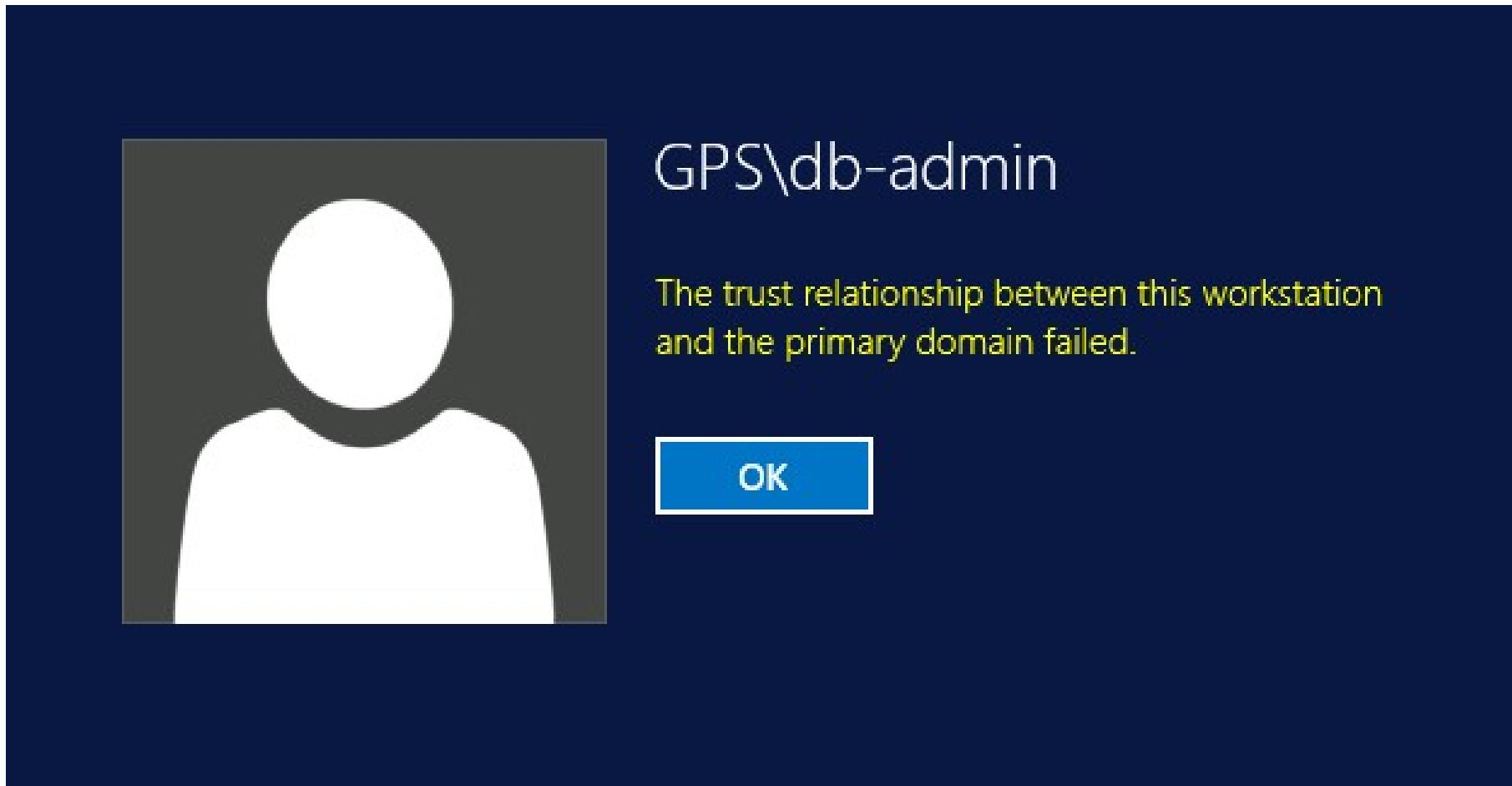


Computer password tools

- nltest /sc_verify:gps
- nltest /sc_reset:gps
- **netdom resetpwd** /Server:dc1 /UserD:gps\domain-admin /PasswordD:Pa\$\$w0rd
 - or dis-join and re-join again
 - **Test-ComputerSecureChannel -Repair**
 - **Reset-ComputerMachinePassword**

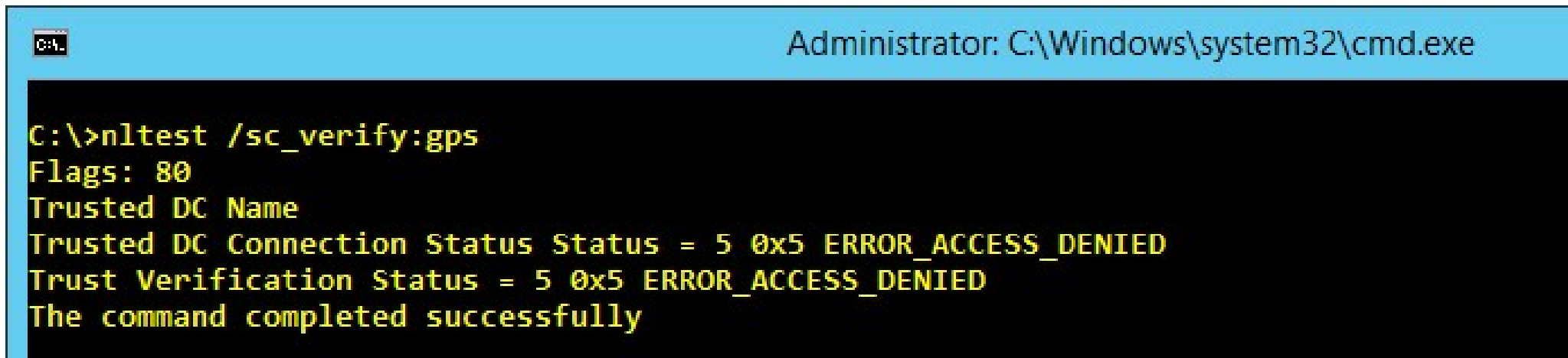
Machine password and secure channel error symptoms **on the affected server**

- Cannot logon locally online (from cache ok)
 - the trust relationship between this workstation and the primary domain failed



Machine password and secure channel error symptoms **on the affected server**

- nltest /sc_verify:gps
 - ERROR_ACCESS_DENIED = 0x5

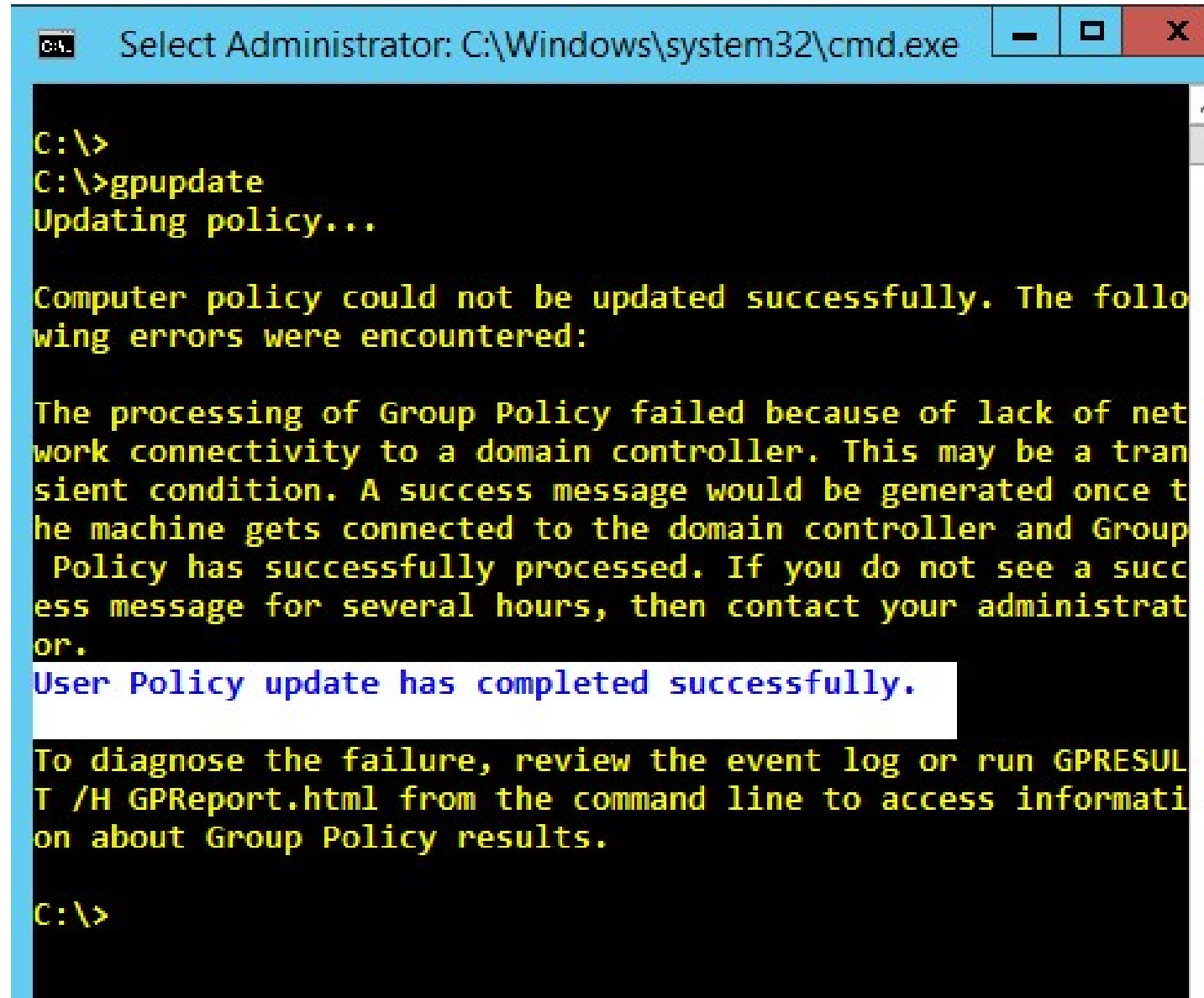


A screenshot of a Windows command prompt window. The title bar is light blue and contains the text "Administrator: C:\Windows\system32\cmd.exe". The command prompt itself has a black background with yellow text. The text displayed is as follows:

```
C:\>nltest /sc_verify:gps
Flags: 80
Trusted DC Name
Trusted DC Connection Status Status = 5 0x5 ERROR_ACCESS_DENIED
Trust Verification Status = 5 0x5 ERROR_ACCESS_DENIED
The command completed successfully
```

Machine password and secure channel error symptoms on the affected server

- gpupdate
 - computer update fails
 - user update ok
- ipconfig /registerdns
 - fails



```

C:\>
C:\>gpupdate
Updating policy...

Computer policy could not be updated successfully. The following errors were encountered:

The processing of Group Policy failed because of lack of network connectivity to a domain controller. This may be a transient condition. A success message would be generated once the machine gets connected to the domain controller and Group Policy has successfully processed. If you do not see a success message for several hours, then contact your administrator.

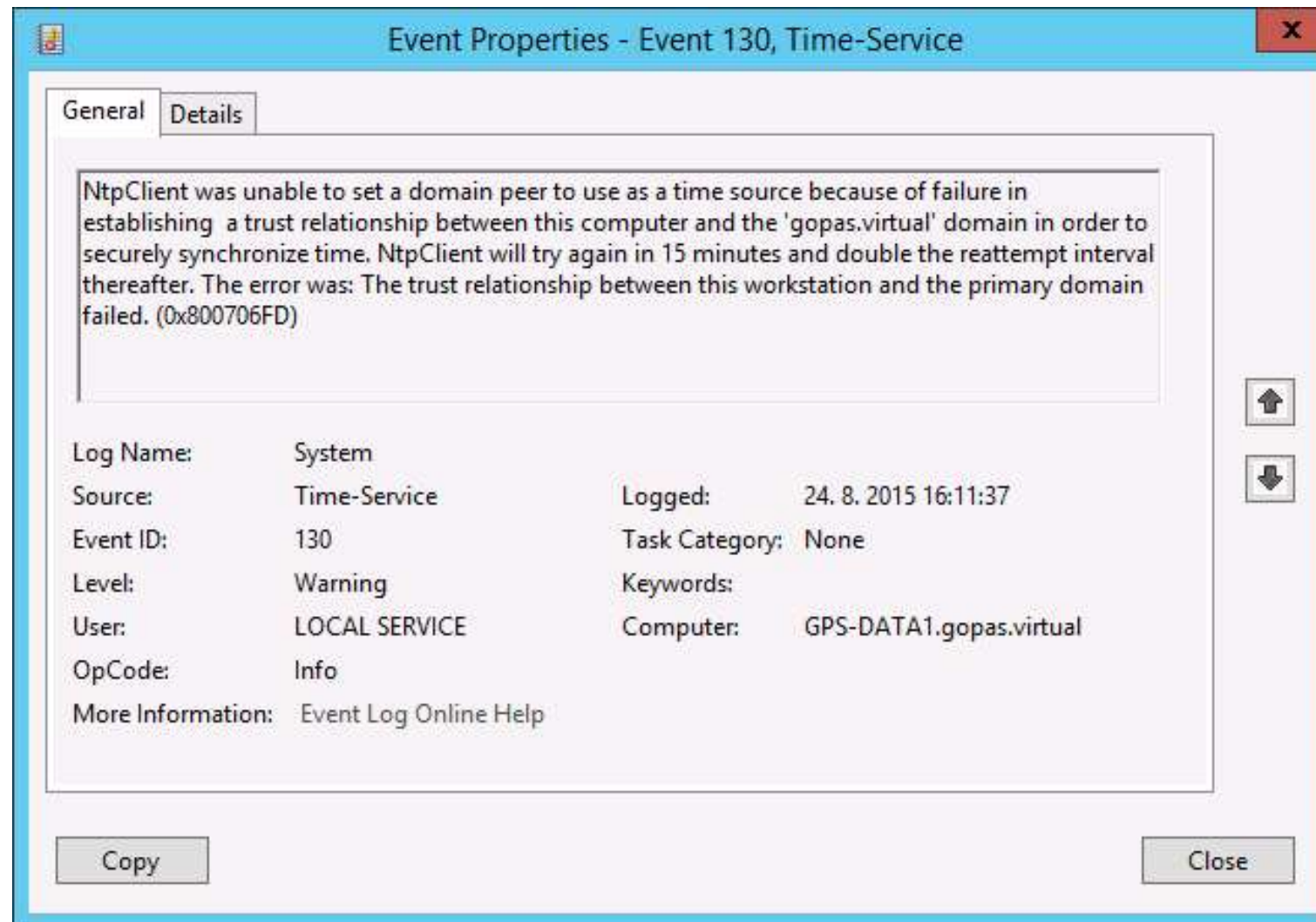
User Policy update has completed successfully.

To diagnose the failure, review the event log or run GPRESULT /H GPREport.html from the command line to access information about Group Policy results.

C:\>
```

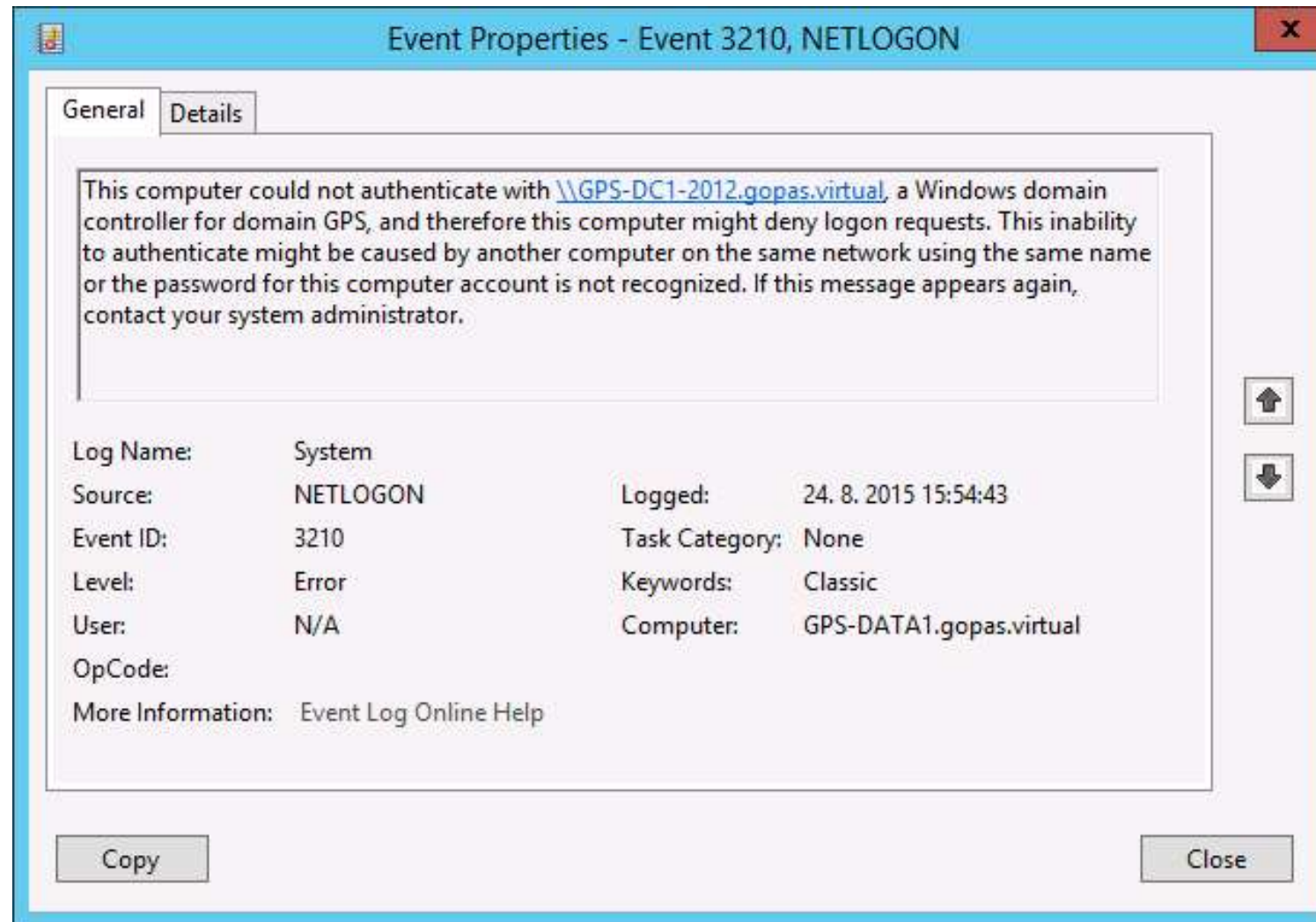
Machine password and secure channel error symptoms **on the affected server**

- Warning, Event ID 130, Time-Service
 - NtpClient was unable to set a domain peer to use as a time source because of failure in establishing a trust relationship between this computer and the domain in order to securely synchronize time.



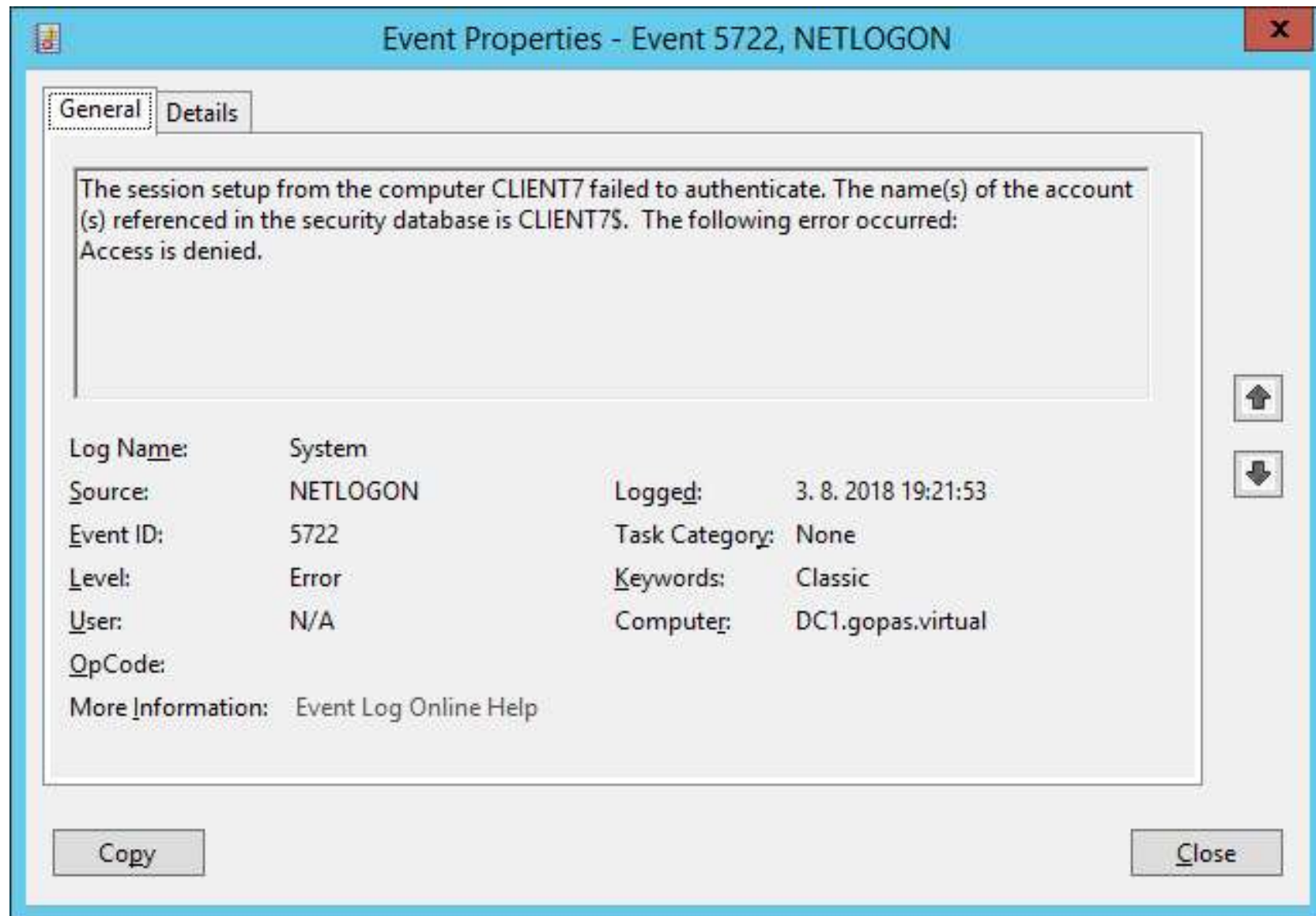
Machine password and secure channel error symptoms **on the affected server**

- Error, Event ID 3210, NETLOGON
 - This computer could not authenticate with a Windows domain controller for domain, and therefore this computer might deny logon requests. This inability to authenticate might be caused by the password for this computer account is not recognized.



The session setup from computer failed to authenticate when doing NTLM pass-through

- Error, Event ID 5722, NETLOGON



Machine password and secure channel error symptoms **from the remote client side**

- NTLM authentication fails with
 - the trust relationship between this workstation and the primary domain failed
- Kerberos authentication fails with
 - the target principal name is incorrect

C:\

Administrator: C:\Windows\system32\cmd.exe

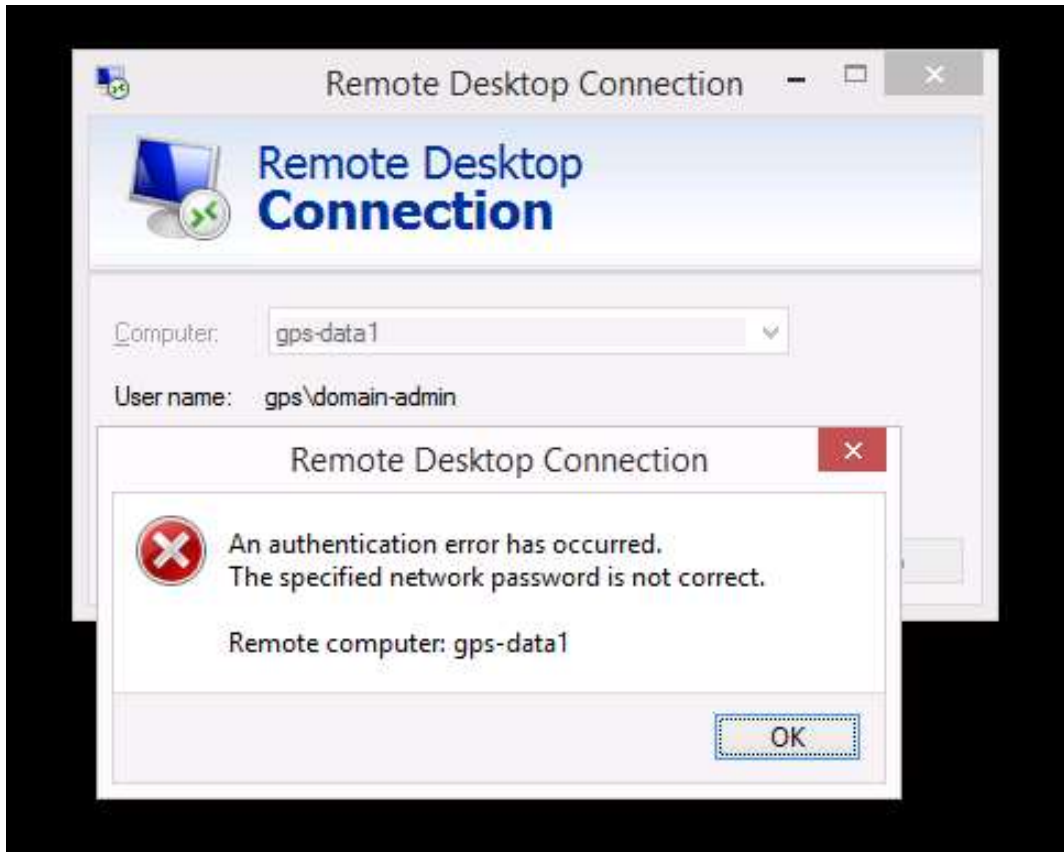
```
C:\>
C:\>dir \\10.10.0.16\doc
The trust relationship between this workstation and the primary domain failed.

C:\>dir \\gps-data1\doc
The target account name is incorrect.

C:\>_
```


Machine password and secure channel error symptoms **from the remote client side**

- RDP access fails
 - an authentication error has occurred. The specified network password is not correct



Machine password and secure channel error troubleshooting on DCs

- pwdLastSet attribute

The screenshot shows the 'GPS-DATA1 Properties' dialog box with the 'Attribute Editor' tab selected. The 'Attributes' list contains the following entries:

Attribute	Value
profilePath	<not set>
proxiedObjectName	<not set>
proxyAddresses	<not set>
pwdLastSet	24. 8. 2015 16:06:37 Central Europe Dayligh
registeredAddress	<not set>
replPropertyMetaData	AttID Ver Loc.USN Org.DSA
replUpToDateVector	<not set>
repsFrom	<not set>
repsTo	<not set>
revision	<not set>
rid	<not set>

Machine password and secure channel error troubleshooting on DCs

- **unicodePwd** attribute metadata
 - repadmin /showobjmeta
 - repadmin /replsummary

```
C:\>repadmin /showobjmeta gps-dc1-2012 CN=GPS-DATA1,OU=Computers,OU=Company,DC=gopas,DC=virtual

30 entries.
Loc.USN                               Originating DSA   Org.USN   Org.Time/Date      Ver Attribute
=====
23206   Prague\GPS-DC1-2012   23206   2015-08-23 17:37:02      1 objectClass
23206   Prague\GPS-DC1-2012   23206   2015-08-23 17:37:02      1 cn
23206   Prague\GPS-DC1-2012   23206   2015-08-23 17:37:02      1 instanceType
23206   Prague\GPS-DC1-2012   23206   2015-08-23 17:37:02      1 whenCreated
23215   Prague\GPS-DC1-2012   23215   2015-08-23 17:37:02      9 ntSecurityDescriptor
23206   Prague\GPS-DC1-2012   23206   2015-08-23 17:37:02      1 name
34412   Prague\GPS-DC2-2003   29145   2015-08-23 18:14:55      4 userAccountControl
23207   Prague\GPS-DC1-2012   23207   2015-08-23 17:37:02      1 codePage
23207   Prague\GPS-DC1-2012   23207   2015-08-23 17:37:02      1 countryCode
46433   Prague\GPS-DC1-2012   46433   2015-08-24 16:06:37      9 dBCSPwd
23206   Prague\GPS-DC1-2012   23206   2015-08-23 17:37:02      1 localPolicyFlags
23207   Prague\GPS-DC1-2012   23207   2015-08-23 17:37:02      1 logonHours
46433   Prague\GPS-DC1-2012   46433   2015-08-24 16:06:37      9 unicodePwd
46433   Prague\GPS-DC1-2012   46433   2015-08-24 16:06:37      9 ntPwdHistory
46433   Prague\GPS-DC1-2012   46433   2015-08-24 16:06:37      9 pwdLastSet
```

Service Accounts

- Services, jobs and IIS application pools run under some service identity
- NT AUTHORITY\System
- NT AUTHORITY\Network Service
- NT AUTHORITY\Local Service
- NT SERVICE*
- IIS APPPOOL*
- <domain>*

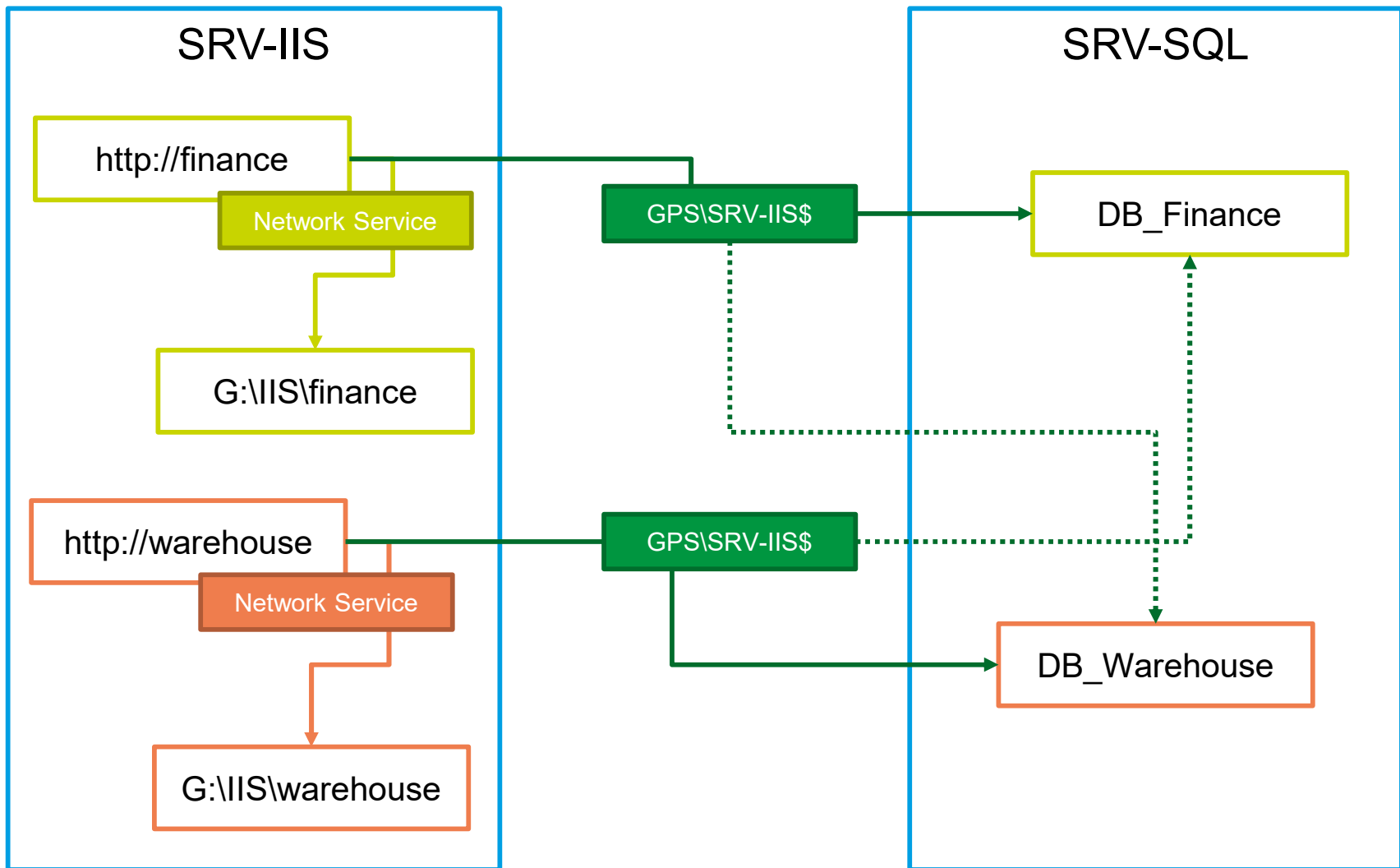
Service identities on Windows XP+

- SYSTEM
 - local Administrators
 - uses COMPUTER\$ to access network resources
 - must use Kerberos on 2003- (cannot use NTLM)
 - 2008+ Allow Local System to use computer identity for NTLM
- Network Service
 - local Users
 - uses COMPUTER\$ to access network resources
- Local Service
 - local Users
 - anonymous network access

Network Service vs. Local Service

- **DNS Client** must register DNS name
 - NT AUTHORITY\Network Service
 - dynamic dns update requires Kerberos authentication
- **DHCP Client** although is a networking service, does not require any authentication
 - NT AUTHORITY\Local Service

Network Service does **not** even have **local** isolation



NT SERVICE

snmptrap.exe:2696 Properties

Image Performance Performance Graph Disk and Network Services
Threads TCP/IP Security Environment Strings

User: NT SERVICE\SNMPTRAP
SID: S-1-5-80-3964583643-2633443559-2834438935-3739664028-1580655619
Session: 0 Logon Session: 43698
Virtualized: No

Group	Flags
Logon SID (S-1-5-5-0-276115)	Owner
Everyone	Mandatory
Mandatory Label\High Mandatory Level	Integrity
LOCAL	Mandatory
CONSOLE LOGON	Mandatory
NT AUTHORITY\Authenticated Users	Mandatory
NT AUTHORITY\This Organization	Mandatory
BUILTIN\Users	Mandatory
NT AUTHORITY\SERVICE	Mandatory
NT SERVICE\ALL SERVICES	Mandatory

Group SID: n/a

Privilege	Flags
SeChangeNotifyPrivilege	Default Enabled

Permissions

OK Cancel

IIS APPPOOL

w3wp.exe:892 Properties

Image Performance Performance Graph Disk and Network Threads

TCP/IP Security Environment Strings

User: IIS APPPOOL\ISAppPool
SID: S-1-5-82-2323993230-3314435900-2952571610-589578806-3123142537
Session: 0 Logon Session: 49315
Virtualized: No

Group	Flags
Logon SID (S-1-5-5-0-299792)	Mandatory
Everyone	Mandatory
Mandatory Label\High Mandatory Level	Integrity
LOCAL	Mandatory
CONSOLE LOGON	Mandatory
NT AUTHORITY\Authenticated Users	Mandatory
NT AUTHORITY\This Organization	Mandatory
BUILTIN\Users	Mandatory
BUILTIN\IIS_IUSRS	Mandatory
NT AUTHORITY\SERVICE	Mandatory
S-1-5-82-0	Mandatory

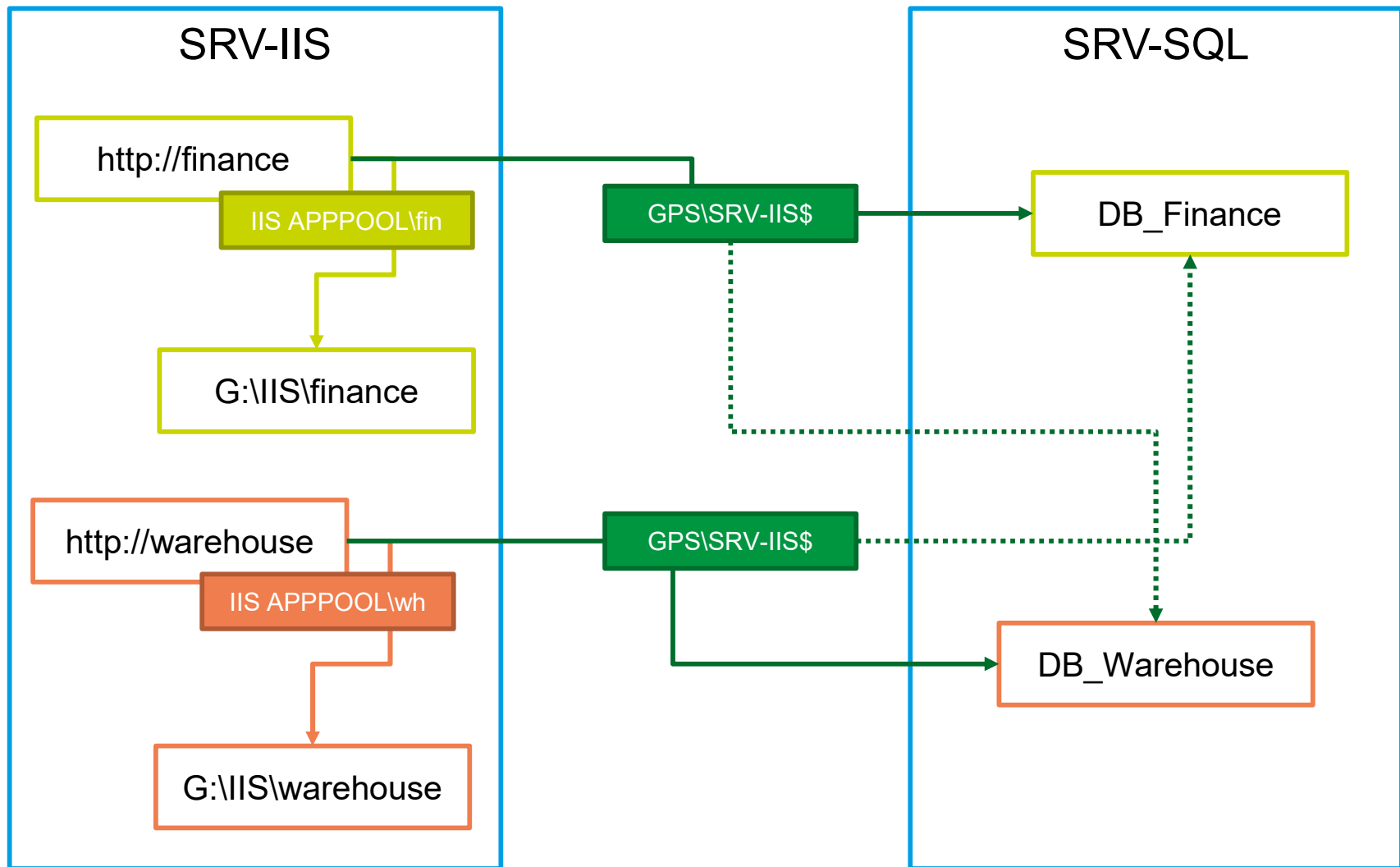
Group SID: n/a

Privilege	Flags
SeAssignPrimaryTokenPrivilege	Disabled
SeAuditPrivilege	Disabled
SeCreateGlobalPrivilege	Default Enabled
SeChangeNotifyPrivilege	Default Enabled
SeImpersonatePrivilege	Default Enabled
SeIncreaseQuotaPrivilege	Disabled
SeIncreaseWorkingSetPrivilege	Disabled

Permissions

OK Cancel

NT SERVICE and IIS APPPOOL have **local** isolation only



Local administrator can obtain service and scheduled task passwords

The screenshot shows the main interface of Cain & Abel, a network traffic analysis tool. The left sidebar displays a tree view of security-related items, with 'LSA Secrets' selected. The main pane shows the details of the selected item, displaying a list of system secrets with their corresponding hexadecimal and ASCII representations. The 'DefaultPassword' section is visible at the top of the list. The 'SC_MSSQL\$INFOSYS' entry is highlighted, showing the password 'P.a.\$.\$w.0.r.d.'. The 'SC_SNMPTRAP' and 'SC_SQLAgent\$INFOSYS' entries are also visible below it. The bottom status bar indicates the current selection is 'LSA Secrets'.

File View Configure Tools Help

Decoders Network Sniffer Cracker Traceroute CCDU Wireless Query

Cached Passwords
Protected Storage
LSA Secrets
Wireless Passwords
IE7 Passwords
Windows Mail Passwords
Dialup Passwords
Edit Boxes
Enterprise Manager
Credential Manager

DefaultPassword

DPAPI_SYSTEM

01	00	00	00	EF	3C	2D	F2	7B	74	5E	4C	A5	44	04	5F	<-. {t^L.D._
36	D6	BB	01	A7	C6	A5	D0	11	C4	3D	6D	CC	AF	4C	3F	6.....=m..L?
33	7C	CC	47	2E	EE	44	C2	72	BD	2F	2C					3 .G..D.r./,

NL\$KM

7F	CA	67	D9	5D	51	1E	F4	86	D1	29	F6	4A	E3	28	23	..g.]Q....).J.(#
C8	75	76	F3	42	7C	82	9D	99	67	63	0D	77	37	B2	18	.uv.B ...gc.w7..
D2	D2	B5	FE	B7	01	71	F3	60	2C	FC	A3	73	FC	C9	D4	q.,...s...
B1	0E	91	83	F6	63	1C	9C	21	94	B6	F8	49	12	2C	FA	c..!...I.,.

SC_MSSQL\$INFOSYS

50	00	61	00	24	00	24	00	77	00	30	00	72	00	64	00	P.a.\$.\$w.0.r.d.
----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	-------------------

_SC_SNMPTRAP

_SC_SQLAgent\$INFOSYS

LSA Secrets

<http://www.oxid.it>

AppPool passwords

- C:\Windows\System32\InetSrv\APPCMD LIST
APPPOOL MyPool /text:*

Task scheduler passwords

Create Task

General Triggers Actions Conditions Settings

Name: Database Cleanup

Location: \

Author: ondr8\ondrej

Description:

Security options

When running the task, use the following user account:
ondr8\ondrej Change User or Group...

☐ Run only when user is logged on

☒ Run whether user is logged on or not

☐ Do not store password. The task will only have access to local computer resources.

☐ Run with highest privileges

☐ Hidden

Configure for: Windows Vista™, Windows Server™ 2008

OK Cancel

Isolation

Domain	Account	Network Password	Groups	Local Isolation	Network Isolation	Kerberos PAC Validation	OS
NT AUTHORITY	SYSTEM	automatic 30 days	Administrators	no	MACHINE\$	no	2000
NT AUTHORITY	Network Service	automatic 30 days	Users	no	MACHINE\$	no	XP
NT AUTHORITY	Local Service	no	Users	no	anonymous	no	XP
NT SERVICE	<serviceName>	automatic 30 days	Users	yes	MACHINE\$	no	Vista 2008
IIS APPPOOL	<appPoolName>	automatic 30 days	Users	yes	MACHINE\$	no	Vista 2008
<domain>	<userName>	manual	Users	yes	yes	yes	2000
<domain> MSA	<managedSvcAccount>	automatic 30 days	Users	yes	yes	no	7 2008 R2
<domain> gMSA	<groupSvcAccount>	automatic 30 days	Users	yes	yes	no	8 2012

gMSA

New-ADServiceAccount gsvc-warehouse

Administrator: Windows PowerShell

```
New-ADServiceAccount gsvc-warehouse -DNSHostName gsvc-warehouse.gopas.virtual  
-PrincipalsAllowedToRetrieveManagedPassword gps-web$, gps-sprdp$
```

- do NOT configure the web site yet
 - will use for Kerberos test later
- but you can verify logon with psexec (gsvc-warehouse\$, empty password)

Select Administrator: C:\Windows\system32\cmd.exe

```
C:\>t:\SysInternals\psexec -i -d -u "gps\gsvc-warehouse$" cmd
```

```
PsExec v2.2 - Execute processes remotely  
Copyright (C) 2001-2016 Mark Russinovich  
Sysinternals - www.sysinternals.com
```

```
Password:
```

Task scheduler without password requires S4U

- read `tokenGroupsGlobalAndUniversal` attribute on the service account
- or be member of `Windows Authorization Access Group` (WAAG)
- `Anonymous` access to network resources
 - or enable Kerberos delegation

Password hashes in Active Directory

- Windows 2000 DC
 - **pwd**, LM, MD4 (NT hash)
- Windows 2003 DC
 - **pwd**, LM, MD4 (NT hash), MD5 (advanced digest hash, CHAP)
- Windows 2008+ DC
 - **pwd**, **LM** (not by default), **MD4** (NT hash), MD5, **SHA-1** (Kerberos AES)
- Windows 2025+ DC
 - **pwd**, **LM** (not by default), **MD4** (NT hash), MD5, **SHA-1** (Kerberos AES), **SHA256** (Kerberos AES)
- MD4 NT hash
 - NTLM/MS-CHAP, NTLMv2/MS-CHAPv2, Kerberos DES, Kerberos RC4

repadmin /showobjmeta

- unicodePwd - NTLM MD4
- dBCSPwd - LM
- supplementalCredentials - Digest MD5, cleartext, SHA1
- pwdLastSet - changed on change, reset, but not on enabling Smart Card is Required for Interactive Logon (SMARTCARD_REQUIRED = 0x40000)

Administrator: Windows PowerShell

```
PS C:\>
PS C:\> repadmin /showobjmeta localhost "CN=Kamil R.,OU=People,OU=Company,DC=gopas,DC=virtual"
```

36 entries.

Loc.USN	Originating DSA	Org.USN	Org.Time/Date	Ver	Attribute
=====	=====	=====	=====	===	=====
20542	Prague\GPS-DC1	20542	2023-01-23 20:37:58	1	objectClass
20542	Prague\GPS-DC1	20542	2023-01-23 20:37:58	1	cn
49496	Prague\GPS-DC2	39386	2023-01-24 08:50:56	2	dBCSPwd
20543	Prague\GPS-DC1	20543	2023-01-23 20:37:58	1	logonHours
49496	Prague\GPS-DC2	39386	2023-01-24 08:50:56	2	unicodePwd
49496	Prague\GPS-DC2	39386	2023-01-24 08:50:56	2	ntPwdHistory
49496	Prague\GPS-DC2	39386	2023-01-24 08:50:56	2	pwdLastSet
20543	Prague\GPS-DC1	20543	2023-01-23 20:37:58	1	primaryGroupID
49496	Prague\GPS-DC2	39387	2023-01-24 08:50:56	2	supplementalCredentials
20542	Prague\GPS-DC1	20542	2023-01-23 20:37:58	1	objectSid
20543	Prague\GPS-DC1	20543	2023-01-23 20:37:58	1	accountExpires
49496	Prague\GPS-DC2	39386	2023-01-24 08:50:56	2	lmPwdHistory
20542	Prague\GPS-DC1	20542	2023-01-23 20:37:58	1	displayName
20542	Prague\GPS-DC1	20542	2023-01-23 20:37:58	1	co
20542	Prague\GPS-DC1	20542	2023-01-23 20:37:58	1	department
20542	Prague\GPS-DC1	20542	2023-01-23 20:37:58	1	nTSecurityDescriptor
20542	Prague\GPS-DC1	20542	2023-01-23 20:37:58	1	name
20542	Prague\GPS-DC1	20542	2023-01-23 20:37:58	1	userAccountControl
20543	Prague\GPS-DC1	20543	2023-01-23 20:37:58	1	codePage
20543	Prague\GPS-DC1	20543	2023-01-23 20:37:58	1	countryCode

Real pwdLastSet values from replication metadata

```
# Note: constructed attribute msDS-ReplAttributeMetadata is present since windows 2008
[object[]] $accounts = Get-ADObject -LDAPFilter '(objectClass=user)' `
                        -Properties SAMAccountName, msDS-ReplAttributeMetadata

if ($accounts.Length -gt 0) { foreach ($oneAccount in $accounts) {

    [DateTime] $lastPwdChange = [DateTime]::MaxValue

    [Microsoft.ActiveDirectory.Management.ADPropertyValueCollection] $metadata = `
        $oneAccount.'msDS-ReplAttributeMetadata'

    if ($metadata.Count -gt 0) { foreach ($oneMeta in $metadata) {

        [XML] $xmlMeta = [XML] ($oneMeta -replace '[\x0A\x0D\x00]', '')

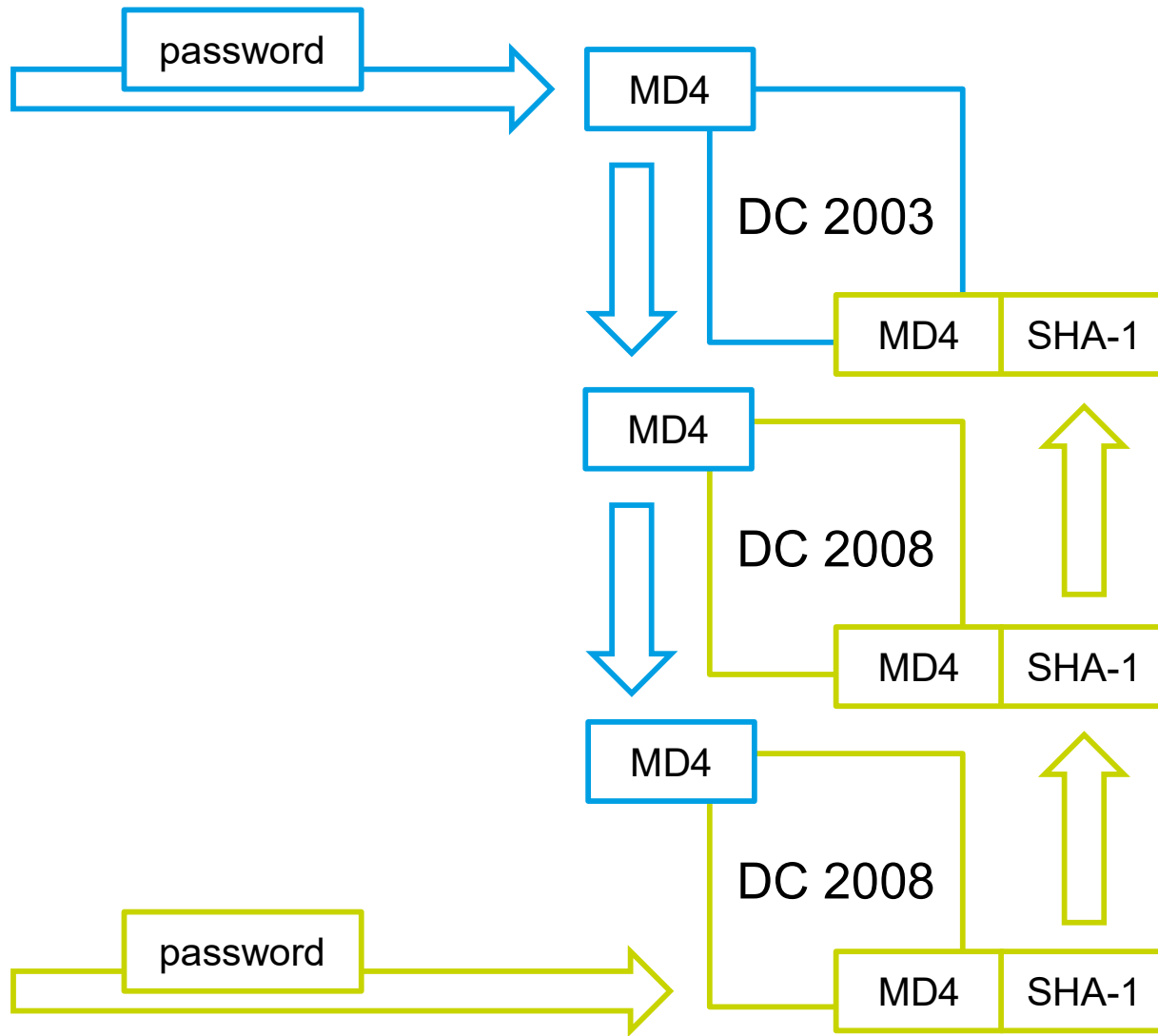
        if ($xmlMeta.DS_REPL_ATTR_META_DATA.pszAttributeName -eq 'unicodePwd') {

            $lastPwdChange = [DateTime]::Parse($xmlMeta.DS_REPL_ATTR_META_DATA.ftimeLastOriginatingChange)
        }
    }}

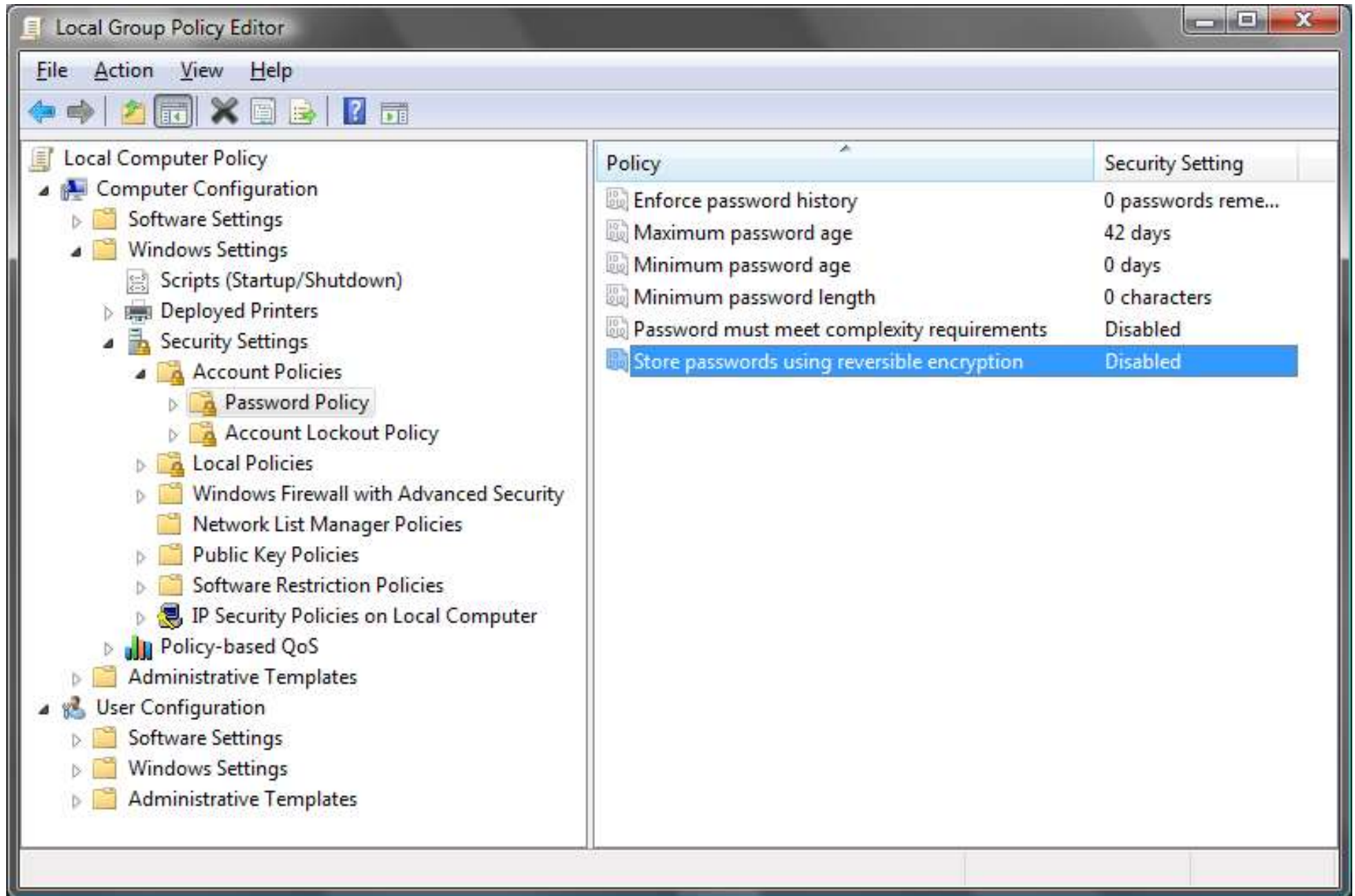
    Add-Member -In $oneAccount -MemberType NoteProperty -Name pwdLastSetReal -Val $lastPwdChange -Force
}}

$accounts | sort pwdLastSetReal | select SAMAccountName, pwdLastSetReal
```

Hash propagation in mixed environments



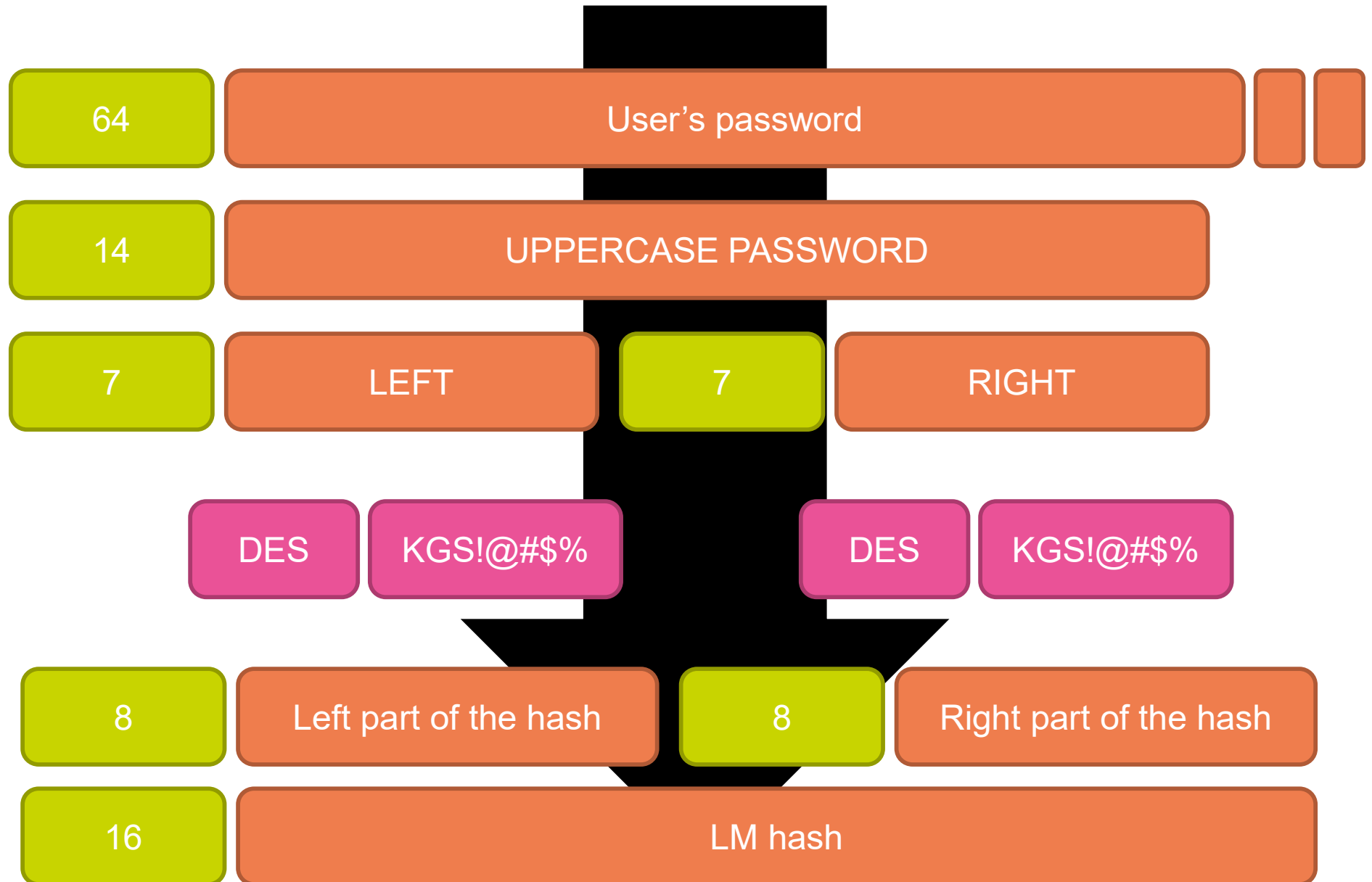
Full-text passwords for digest on 2000



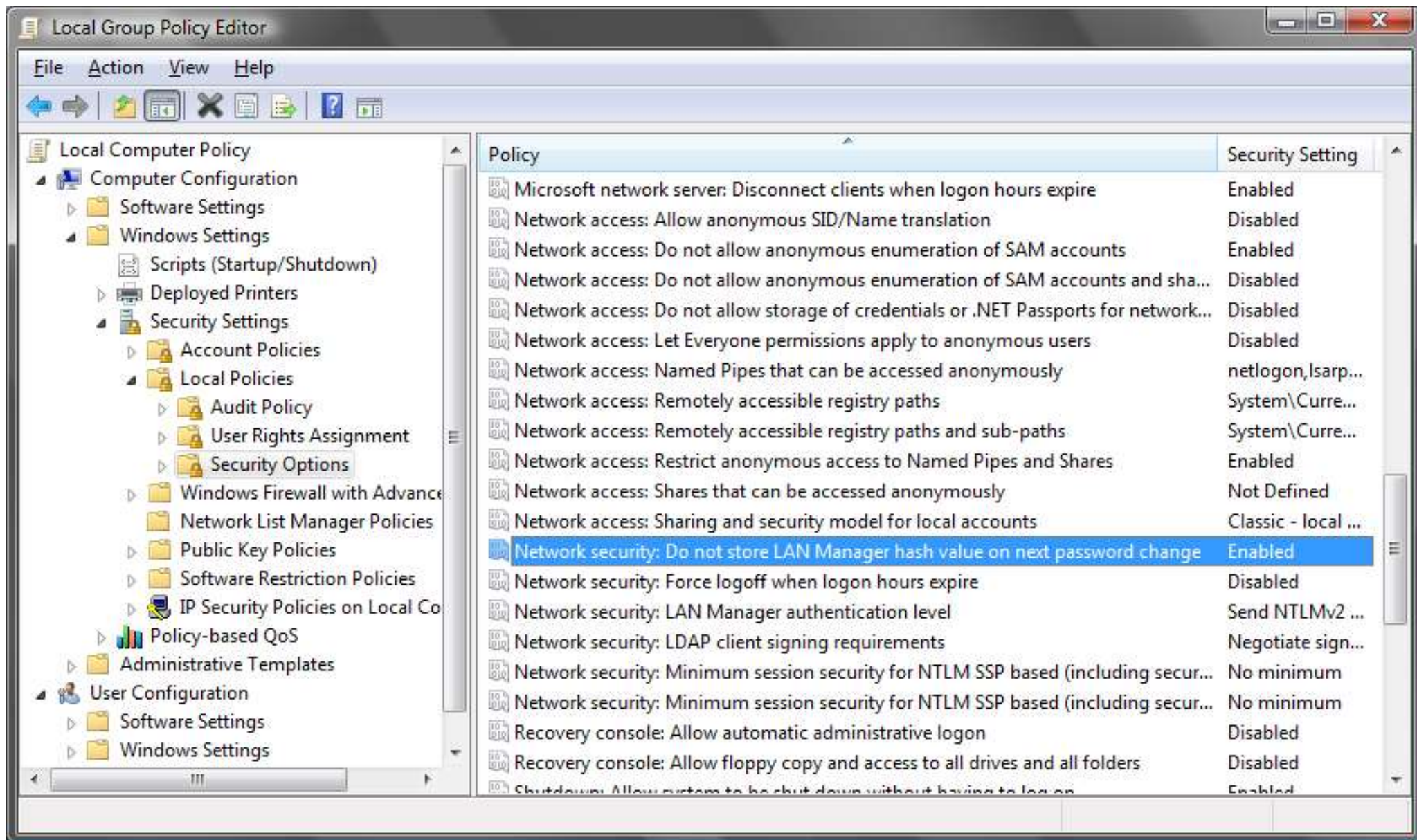
Notes to stored hashes

- Regardless of DFL
 - the hashes are updated only on DC which computes it and replicate
 - after upgrading DFL, some passwords need change before digest/AES
- LM can be disabled
- LM is disabled by default if first domain DC is 2008+
- LM is not stored if password is 15+ chars
- DC can store passwords in full-text

LM hash is extremely weak



Do not store LM hashes



Password longer than 14 chars

- does not generate LM hash at all
 - since Windows 2000+

Password (confidential attribute) replication permissions

- Replication Synchronization
 - invoke DC's own replication operation, such as trigger the following outside of schedule
 - ◆ repadmin /kcc
 - ◆ repadmin /replicate
 - ◆ repadmin /syncall
- Replicate Directory Changes in Filtered Set
 - contains only the GC/RODC attributes
- Replicate Directory Changes
 - contains everything except for secrets and confidential attributes (such as BitLocker and TPM secrets, KDS secrets etc.)
- Replicate Directory Changes All
 - can download the whole replica from a DC including password hashes etc.
 - required by [Azure AD \(AAD\) Connect/DirSync](#) for example when syncing passwords to AAD

Cracking hashes

- Brute-force MD4
 - ca 80^N
 - 12+ chars well unbreakable today
 - hashes from: AD, SAM, LSASS memory, NTLM/Kerberos network authentication
- Rainbow table
 - hash dictionary
 - very quick
 - complete LM table 2 GB
 - 120 GB for mixalphanumeric 8 MD4 character set
 - 4 TB for 9 character set
 - hashes from: AD, SAM, LSASS memory
- SSD vs. RAM ~ 10 000 x slower

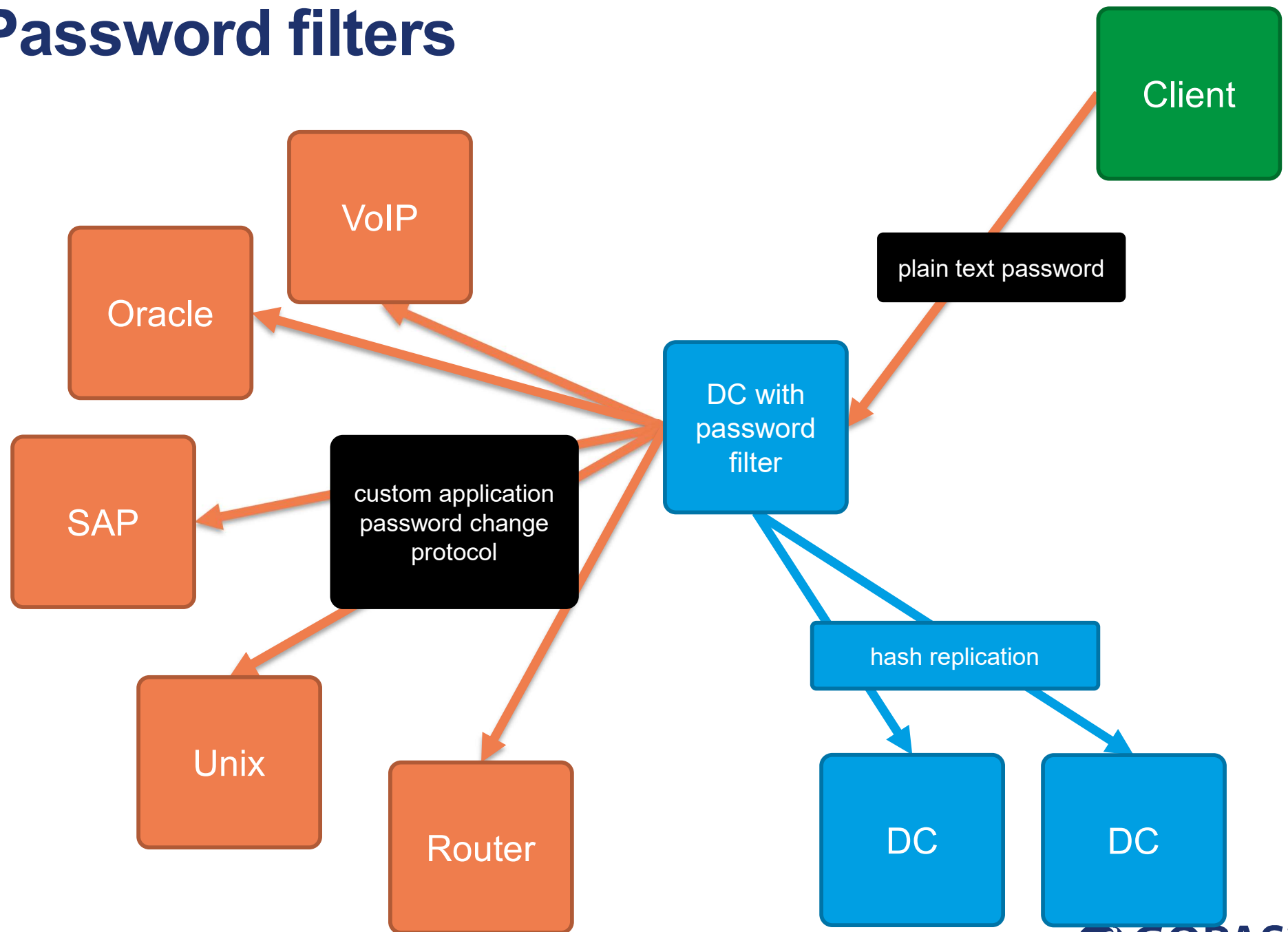
Password policies

- 3 of 4 character classes
 - a-z, A-Z, 0-9, #!@\$%^&*()...
- No 3 and more letters from login sequentially
 - **ondrej**: #.JaME5-BonD38
- Maximum password age
 - prevents colleagues from guessing the password
 - does not affect security against remote anonymous attacks
- Minimum password age
 - only to enforce password history

Password changes

- Go to DC in full-text
 - channel encrypted with Kerberos (original password)
- Password filters .DLL
 - policies
 - identity integration
 - auditing
 - HKLM\System\CCS\Control\Lsa
 - ◆ NotificationPackages = MULTI_SZ
 - ◆ .DLL in System32
 - must be installed on **all writable** DCs

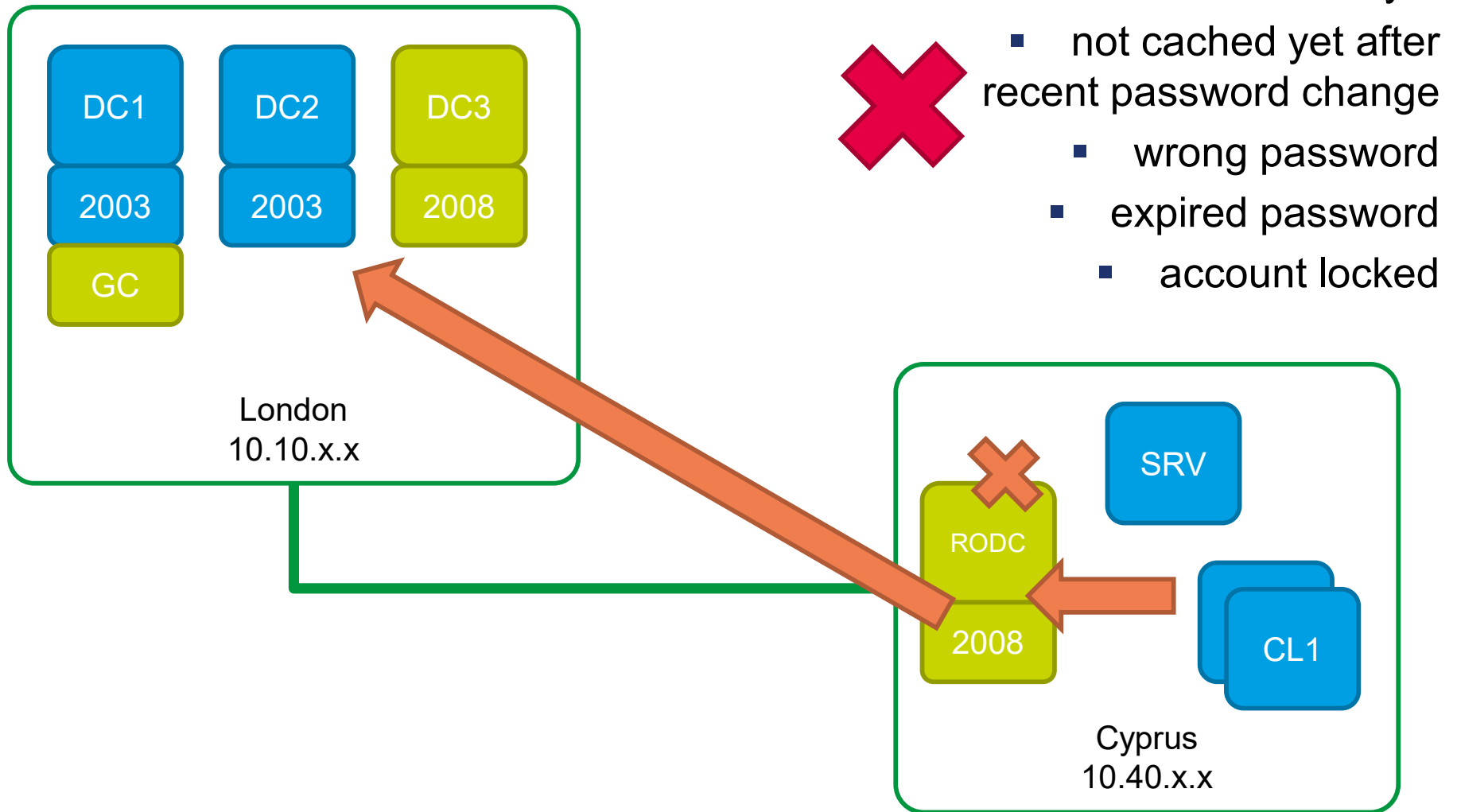
Password filters



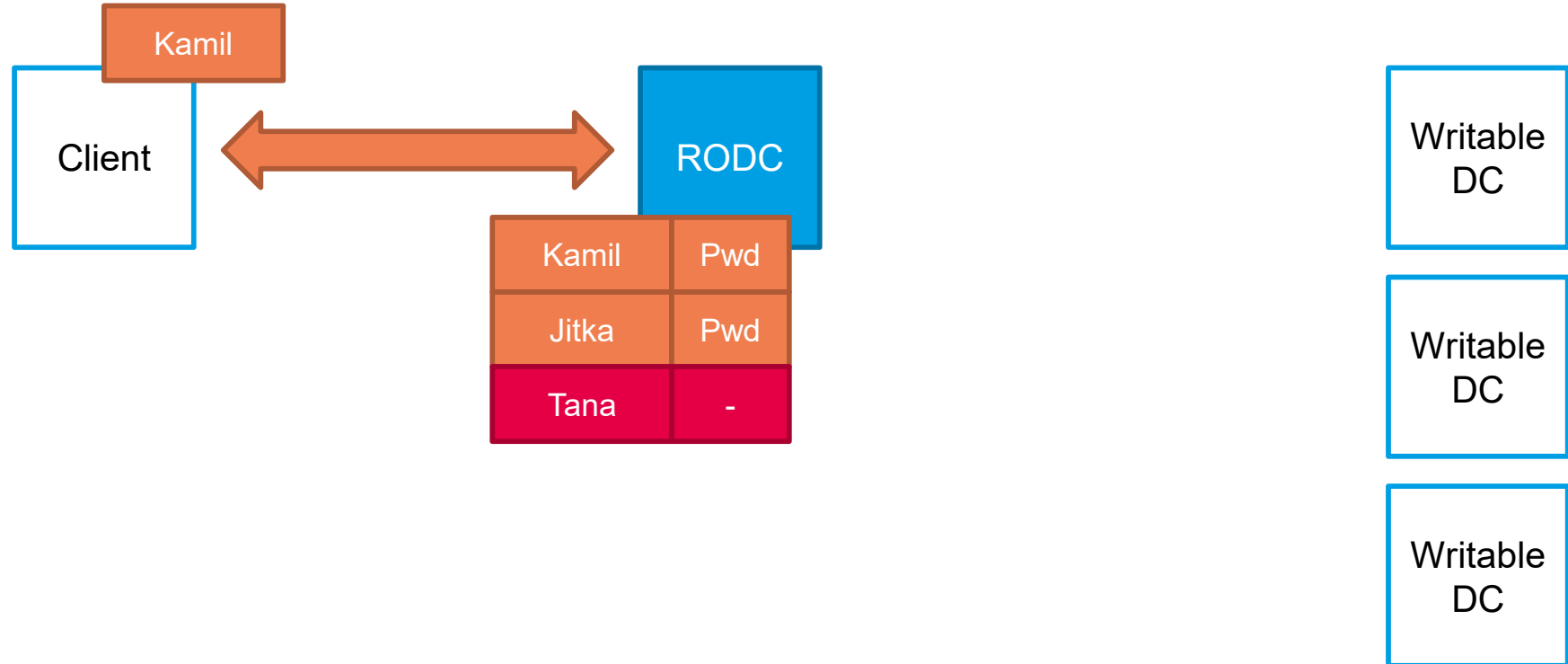
Partial secrets DC (RODC)

- Physically insecure locations
- Caches/replicates **only some** hashes
- Forwards other authentication transparently to writable DCs
- Has a **local Administrators** member who does not need to be member of **Domain Admins** group

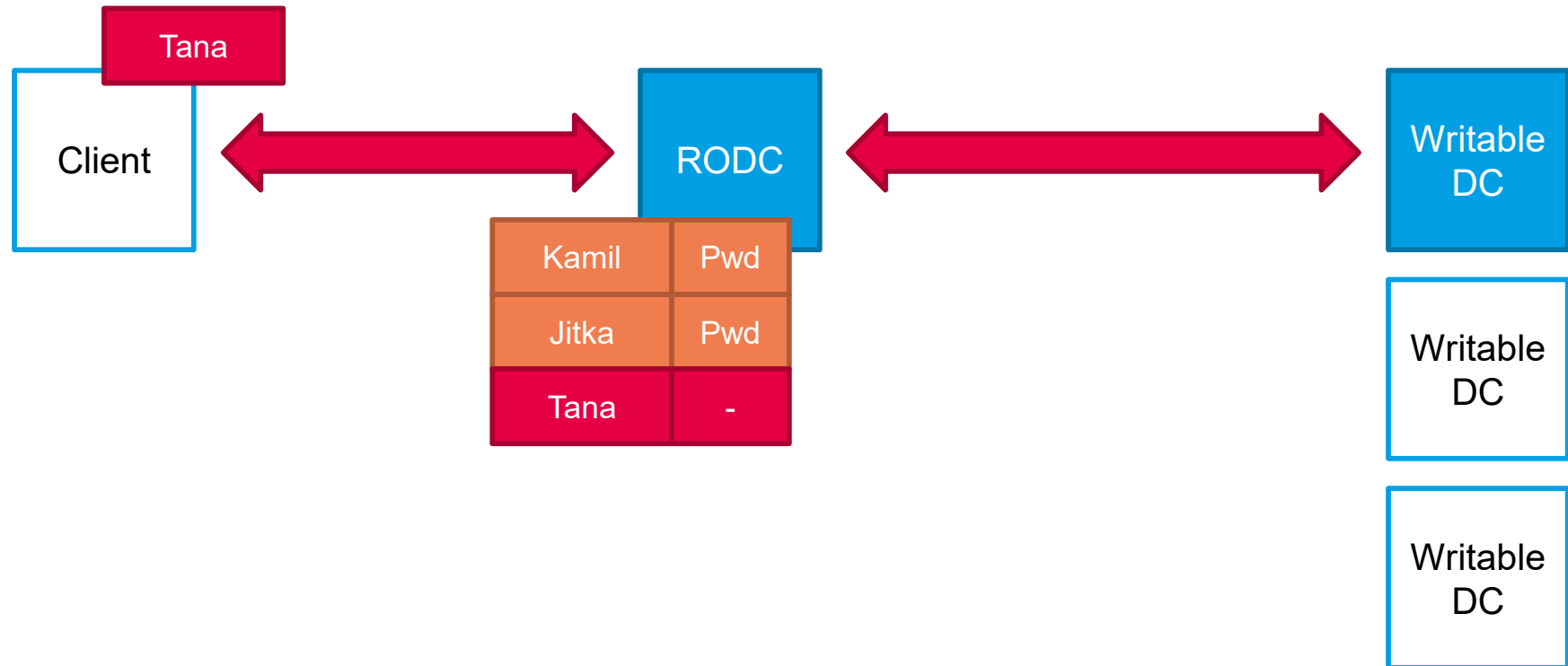
Password caching/forwarding



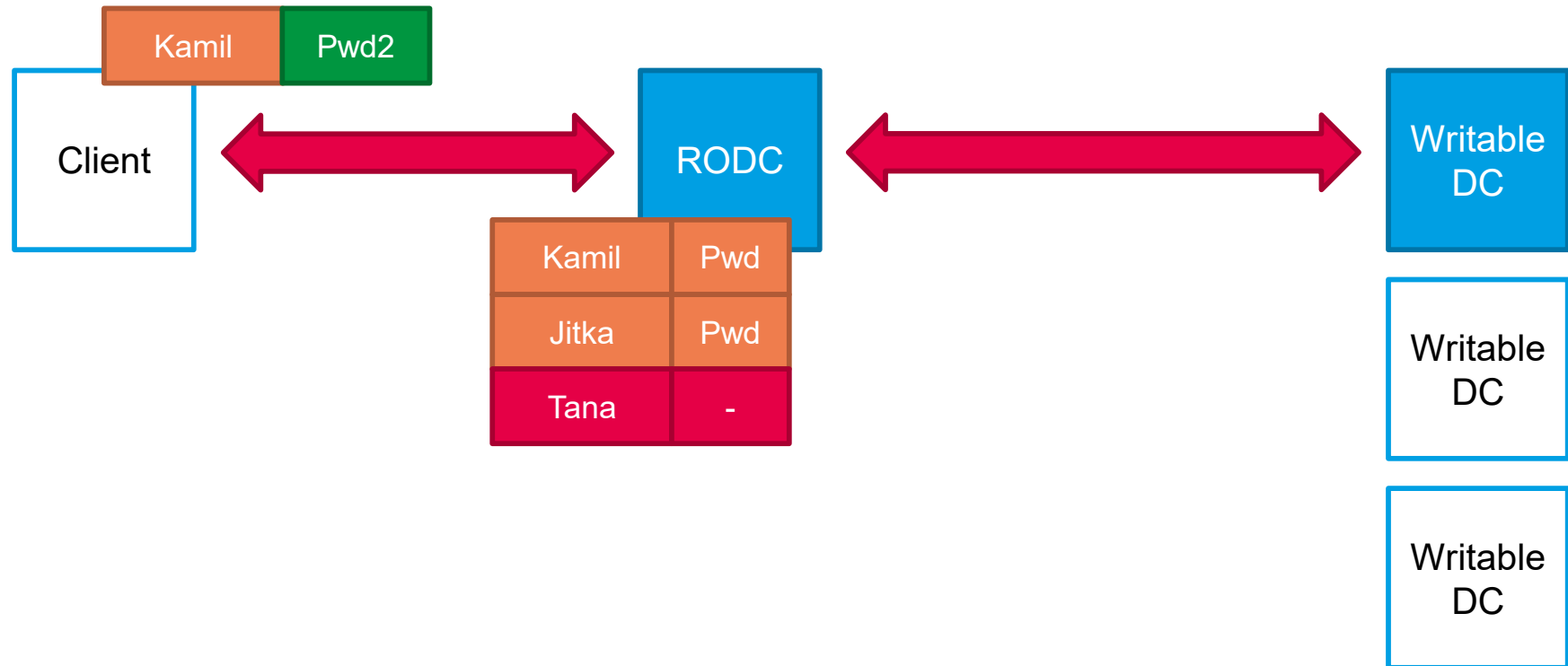
Ticket produced by KDC on RODC



Ticket produced by KDC on a full DC



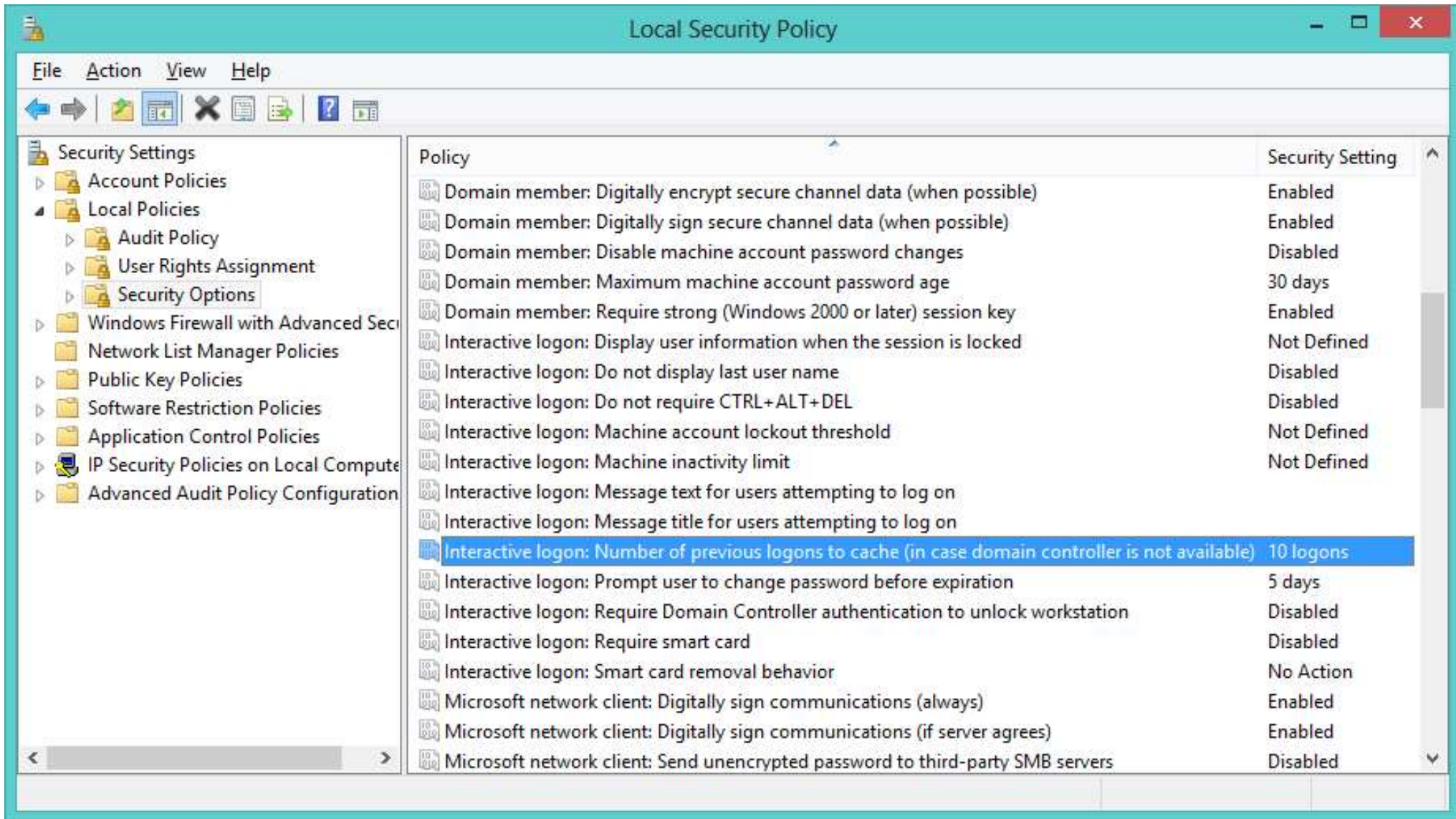
Ticket produced by KDC on a full DC



Cached passwords

- By default 10 different password and access token caches
 - interactive logon
 - service logon
 - batch logon (scheduled tasks, IIS app pools)
- Available only for local logon
- Never expires
 - no regard to password expiration
- No network credentials
 - anonymous access to network resources

Number of previous logons to cache



Cached hashes

- Version 1 (MSCACHEv1)
 - Windows 2000, XP, 2003
 - 2x MD4 salted with user login
 - ◆ prevents rainbow-table attacks
- Version 2 (MSCACHEv2)
 - Windows Vista, 2008+
 - 1000x SHA-1 salted with user login
 - ◆ prevents rainbow-tables and complicates brute-force attacks

Local access token refresh

- Most logons from cache since XP+
 - speed up access token creation
- Log off **twice** to update **local** access token
 - verify always with Process Explorer or WHOAMI

Testing any accounts with /netonly

```
runas /netonly /user:...
```

```
# any account credentials
```

```
# not validated locally
```

```
# validated only at the time of use
```

```
# use @gopas.virtual in order to invoke Kerberos from  
non-domain machines or non-trusted forests
```